PRODCRAFT · TECHNICAL ADVISORY PACK · RESTRICTED

ASSET Voyages website and Congress catalogue

The plan, the design, the gaps and the risk model, prepared for independent review by two senior engineers

Version	1.0 · 31 October 2026
Author	Debanjan Mazumdar, founder, ProdCraft (sole engineer on this bid)
Reviewers	Two external senior engineers (weekend review)
Status	Pre-proposal. No contract is signed. The client is running a competitive consultation.
Source folder	`deliverables/asset_voyages_rfp_2026-10-28/` (referred to as `D/`)
Confidentiality	The client's RFP is restricted to invited suppliers. This pack contains internal pricing. Please do not forward it.

> Conventions used throughout. **Estimate** marks a figure we derived and have not measured. **Verified** marks a fact checked against a primary source, with the date. **UNKNOWN** marks something only the client can tell us. Prices are in euros, excluding VAT (HT), unless stated otherwise.

Contents

0. How to read this, and what we ask of you
- 0.1 Why you are reading this
- 0.2 What we ask you to do
- 0.3 Scoring rubric
- 0.4 What this pack is not
- 0.5 Map of the pack

1. Business context
- 1.1 The client
- 1.2 The RFP
- 1.3 The consultation posture
- 1.4 Links
- 1.5 Commercial frame (internal; you may see the numbers)
- 1.6 Questions for the reviewers

2. Requirements, complete
- 2.1 Outcomes, governance and scope boundaries
- 2.2 Mandatory audit (L0)
- 2.3 Pages and journeys
- 2.4 Forms, enquiries, measurement, permissions
- 2.5 Congress catalogue (L2)
- 2.6 Architecture, security, data protection, handover, quality, SEO, acceptance
- 2.7 The 30 questions and their defaults
- 2.8 What the clarifications reply (31 October) promised
- 2.9 Questions for the reviewers

3. What exists today
- 3.1 The workspace
- 3.2 Reusable assets, with paths
- 3.3 What the concept already proves
- 3.4 What is missing (the honest list)
- 3.5 Capability matrix
- 3.6 Questions for the reviewers

4. System design
- 4.1 Domain model
- 4.2 State machines
- 4.3 Invariants
- 4.4 Roles
- 4.5 Permissions matrix
- 4.6 Data retention and export
- 4.7 CSV import model
- 4.8 i18n and SEO migration model
- 4.9 Questions for the reviewers

5. Architecture
- 5.1 Components
- 5.2 Topology and trust boundaries
- 5.3 Data flows
- 5.4 Environments
- 5.5 Deployment and rollback
- 5.6 Backups and restore
- 5.7 Observability
- 5.8 Security
- 5.9 Failure modes and fallbacks
- 5.10 Alternatives considered
- 5.11 Questions for the reviewers

5.12 Engineering specifics (added at pre-review QA)

6. Build plan
6.1 Contracts before code
6.2 Walking skeleton (week 1–2)
6.3 Modules
6.4 Test strategy
6.5 CI gates
6.6 Definition of done per milestone
6.7 Handover as a product
6.8 Questions for the reviewers

7. Effort, timeline, price
7.1 Hours
7.2 Included quantities
7.3 Calendar
7.4 Price options and market evidence
7.5 Three-year total cost of ownership (core only, HT)
7.6 Running costs (paid by ProdCraft inside the plan; accounts in ASSET's name)
7.7 Questions for the reviewers

8. Risk model and grading
8.1 Complexity
8.2 Confidence model
8.3 The 11-lens panel pass on this plan
8.4 The five-expert view
8.5 Questions for the reviewers

9. KPIs and acceptance metrics per stage
9.1 J0 Kickoff
9.2 J1 Audit and discovery
9.3 J2 UX and UI
9.4 J3 Core website
9.5 J4 Congresses
9.6 J5 Pre-launch
9.7 J6 Stabilisation (4 weeks)
9.8 Post-launch (monthly, in the plan)
9.9 Questions for the reviewers

10. Open decisions and asks for the reviewers
10.1 Open decisions
10.2 What we ask you to tell us
10.3 Questions for the reviewers
10.4 Scoring sheet

Appendix A. The 30 questions with defaults

Appendix B. Glossary

Appendix C. File index of the deliverable folder

Appendix D. Sources

Appendix E. Pre-review QA log

0. How to read this, and what we ask of you

0.1 Why you are reading this

ProdCraft is a one-person studio. The founder builds with an AI-assisted workflow (Claude Code plus a set of deterministic scripts, gates and audits described in §3). We have been invited, alongside other suppliers, to bid on a redesign of a French business-travel agency's website, with a structured Congress catalogue, an enquiry back-office and an editor console. The bid is winnable. The build is also larger than anything we have shipped as a single product: roughly 40% of the scope rests on code we have run in production before; the other 60% is new.

We want two people who did not write the plan to try to break it before the client does. You have the weekend. Please be as hard on it as you would be in a design review at work. Comments like "this is fine" don't help us; comments like "your restore drill doesn't prove RTO because X" do.

0.2 What we ask you to do

1. Read §1–§2 quickly, for context. They describe the client and the requirement; there is little to grade there except whether we understood it.
2. Read §3–§9 carefully. This is the plan: what exists, what we design, how we build it, what it costs, what can go wrong and how we measure it.
3. For **each numbered section**, give a score from 1 to 10 and a comment. Use the scoring sheet in §10.4. A rubric is below.
4. Answer the **Questions for the reviewers** at the end of each section where you have a view. Skip the ones you don't.
5. In §8.2, **re-score the risk table**: put your own probability next to ours for each risk. That is the single most useful thing you can give us.
6. In §10, tell us which of the open decisions you would take differently, and why.

0.3 Scoring rubric

Score	Meaning
9–10	You would approve this in a design review at your company with no changes.
7–8	Sound. Minor gaps, none of which put delivery at risk.
5–6	Workable, but at least one gap would likely cause a slip, a defect at acceptance, or a cost overrun.
3–4	A material flaw: you would block it until it is fixed.
1–2	Wrong approach. Start again.

Please grade the plan against the client's requirement and a one-person team, not against what a ten-person team at a large company would do. Where the right answer is "hire someone", say so; that is a legitimate finding.

0.4 What this pack is not

- It is not the client proposal. The proposal (`D/proposal/ProdCraft_ASSET_Voyages_Proposal_v1.0_2026-10-28.pdf`) is a separate, client-facing document and will be revised after the client answers our 30 questions.
- It is not code. The production system does not exist yet. The concept site exists and is live (links in §1.4); everything in §4–§6 is design.
- It does not contain secrets, credentials or other ProdCraft clients' names. Where we refer to prior builds we describe them anonymously ("a public job-board build", "two live bilingual sites").

0.5 Map of the pack

§	Title	What to grade
1	Business context	Did we understand the client and the competitive position?
2	Requirements, complete	Is every RFP cell mapped to a function and a test?
3	What exists today	Is the capability assessment honest? Is the lift path credible?

§	Title	What to grade
4	System design	Domain model, state machines, invariants, permissions, i18n, SEO.
5	Architecture	Components, trust boundaries, environments, backups, observability, security, failure modes.
6	Build plan	Sequence, modules, tests, CI gates, definition of done, handover.
7	Effort, timeline, price	Hours, calendar, price options, TCO.
8	Risk model and grading	Complexity, confidence model, 11-lens and 5-expert review.
9	KPIs per stage	Are the measures meaningful, measurable and owned?
10	Open decisions, scoring sheet	Your calls on the open choices.
A–D	Appendices	Questions and defaults, glossary, file index, sources.

1. Business context

1.1 The client

ASSET Voyages is a business-travel agency based at 58 rue Jean-Pierre Timbaud, 92130 Issy-les-Moulineaux, France (source: RFP letterhead). It is a member of the **Selectour Affaires** network. Its current website says, verbatim (fetched 28 October 2026): « agence de voyages d'Affaires à taille humaine, membre du réseau Selectour Affaires », and « Avec plus de 122 agences et plateaux d'affaires en France, Selectour Affaires constitue le premier réseau dédié aux voyages d'affaires » (the 122 figure is undated on their site).

It runs three activities, which the RFP and the new site keep distinct:

Activity	What it is	Primary conversion
Business Travel	Managed corporate travel for SMEs and larger accounts: booking, travel policy, reporting, expenses, invoicing, 24/7 assistance ("disponible 24h/24, 7 jours/7" on today's site).	Travel review request, account/demo request (form F01).
MICE	Meetings, Incentives, Conferences and Exhibitions: group travel from 10 people, seminars, incentives, conventions; "un chef de projet dédié".	Progressive brief and quotation request (F02).
International congresses	Travel for delegates attending international (often medical/scientific) congresses, including preferential airline fares under Air France–KLM's Global Meetings & Events (GM&E) programme where ASSET holds the event code.	Flight quotation request pre-filled with the congress (F03).

The client's coordinator is **Veena** (operational coordination; she centralises responses and runs business acceptance). ASSET management approves budget, scope, architecture, mock-ups, milestones and launch.

What we know about the current site (verified 28 October 2026 by `curl -sL`):

- It is served at `asset-voyagesdaffaires.com`, while the RFP letterhead cites `www.assetvoyages.com`. Which domain the new site lives on is question Q6.
- It runs **WordPress 6.9.11** with Slider Revolution 6.2.18 (generator meta tags and `wp-content/` paths).
- The homepage is about 661 words and 69 links; 5,014 px tall on desktop and 10,527 px on mobile (`D/research/live_metrics.json`).
- The client area is labelled « Connexion Traveldoo » (plus IRES and a "Smart" app), whereas the RFP talks about **Wondermiles**. This is question Q23.
- The footer shows both ©2020 and © 2026.

We do **not** know: who hosts it, who owns the domain and DNS, the URL count, traffic, current trackers, CRM, or enquiry volumes. All of this is discovered in the L0 audit (J1) or asked in the 30 questions.

1.2 The RFP

The RFP (Version 0.4 EN, 28 October 2026, 9 pages) asks for a B2B commercial portal that works on mobile and can be managed by the client's own team. It states four expected outcomes:

1. Generate qualified enquiries for Business Travel, MICE and congress-related ticketing.
2. Enable Veena and a backup editor to publish content and Congress listings without a developer.
3. Preserve existing SEO value and keep the current website available throughout the project.
4. Prepare future integration points without making launch dependent on unconfirmed API or SSO access.

Work packages.

Package	Status	Content
L0	Mandatory	Technical and SEO audit, workshops, user journeys, architecture and functional discovery. Recommend keeping or replacing the CMS, with cost justification.
L1	Mandatory	Design, CMS, priority French content, Business Travel and MICE pages, forms, measurement, SEO migration, security and training.

Package	Status	Content
L2	Mandatory	Congress catalogue, search, listings, business workflow, permissions, forms, CSV import/export and moderation.
L3	Optional	Wondermiles feasibility and integrations, SSO/API and account creation, subject to permissions.
L4	Optional	Controlled AI ingestion, human approval, monitoring and logs.

L0+L1+L2 must work without L3 or L4. Ticket issuance and the flight booking engine stay outside the CMS. Advertising, paid CRM software, bulk scraping and automatic publication are out by default.

Milestones (each needs written approval).

Milestone	Deliverable
J0 Kickoff	Team, access inventory, schedule and responsibilities.
J1 Audit and discovery	Architecture, SEO inventory, baseline, backlog and risks.
J2 UX and UI	Wireframes, desktop/mobile mock-ups and design system.
J3 Core website	Pages, CMS, forms and tracking on staging.
J4 Congresses	Tested catalogue, filters, statuses, listings and enquiries.
J5 Pre-launch	SEO migration, tests, fixes, training, backup and rollback plan.
J6 Stabilisation	Monitoring, fixes, access, source code, exports and closure of outstanding items.

The 12–18 week timeframe is "indicative". Payments are negotiated against accepted milestones; cutover needs written authorisation from ASSET management.

Acceptance tests T01–T15 (RFP §7, reproduced in full in §2.6). Launch is blocked by any of: a blocking security defect, data loss, a failed form, private-code exposure, or a missing critical redirect. Major defects need express approval and a dated correction plan; minor defects go into an outstanding-items plan.

Essential conditions (RFP §8, verbatim list): ASSET control of accounts and data; responsive and editable website; staging before cutover; documented SEO migration; protection of GM&E codes; core functionality independent of options, and flight ticket issuance outside the CMS; transparent recurring costs, licences and supplier handover.

Assessment criteria (RFP §8): understanding of user journeys, UX, the Congress catalogue, scalability, SEO, security, methodology, team, overall cost and maintenance. "Any partial response must explain the limitation, its impact and a proposed solution."

1.3 The consultation posture

This is a **formal competitive consultation**, not a signed client. The brief says it is "restricted to invited suppliers", that "any clarification that changes the scope will be shared with all invited suppliers", and that "submitting a proposal does not constitute an order". We assume other agencies are quoting. French agencies typically price this scope well above us (market evidence in §7.4).

Consequences we have designed for:

- **Every RFP identifier needs an explicit answer.** F01–F06, C01–C07, T01–T15, J0–J6, L0–L4. A missing line reads as a partial response.
- **Too cheap reads as risk.** A one-person studio at a fraction of market price must over-prove method and handover, or the client's management will (rightly) worry about continuity.
- **"Team" is an assessment criterion** and we are one person plus AI tooling. We answer this with a named lead, effort by role, a documented stack a third party can maintain, and a handover pack treated as a product (§6.7). Whether this is enough is a question for you (§1.6).

Where the consultation stands (31 October 2026).

Date	Event
28 Oct	RFP received. Concept site built and deployed (noindex). 30 questions sent with written defaults.

Date	Event
28 Oct	Three rounds of internal audits on the outgoing pages (11-lens panel + 5 project experts per round). Verdicts moved from FIX FIRST to PASS.
31 Oct	Veena asked seven clarification questions. We replied point by point (`D/01c_Reply_to_clarifications_2026-10-31.md`), with no prices.
6 Nov	Deadline for answers to the 30 questions. Unanswered items follow the stated default.
≤ 10 Nov	Priced proposal sent (24–48 working hours after answers, or by 10 Nov on defaults).

1.4 Links

What	URL	Notes
Current client site	http://asset-voyagesdaffaires.com	WordPress 6.9.11 (verified 28 Oct 2026).
Our concept (home)	https://asset-voyages-redesign.pages.dev/	noindex. Scroll-scrubbed film « Du brief au retour », offer cards, live Congress catalogue demo with 12 fictional sample listings, three contact journeys.
Pitch page	https://asset-voyages-redesign.pages.dev/pour-asset/	Why the concept is shaped this way, per-activity benefit table.
Console mock-up	https://asset-voyages-redesign.pages.dev/console/	Static mock of the editor console: tiles, Pages, Congresses, Enquiries, GM&E explanation. Buttons show a toast; nothing persists.
Questions page	https://asset-voyages-redesign.pages.dev/questions/	The 30 questions with defaults, anchors `#q1` … `#q30`, fillable answer sheet.

The concept was built to show direction and make the Congress journey concrete. It is **not** a feature list; the proposal will carry a table marking every element as included, optional or illustration only (promised in the 31 Oct reply).

1.5 Commercial frame (internal; you may see the numbers)

Price options under consideration (from `D/20_Internal_Founder_QA.md`; all HT; detail and market evidence in §7):

Option	Build	Monthly plan	Notes
Lean	€4,000 (L0 included, L1 €2,500, L2 €1,500)	€600/month, 12-month minimum	The founder's original constraint. ≈ €15/hour on the 265 h planning figure.
Recommended	**€7,500**	**€600/month, 12-month minimum**	≈ €28/hour on 265 h. Still far below market.
Fair solo	€9,500–12,000	€600–750/month	What a solo senior freelancer at a low market rate would charge.
Market	€18,000–25,000	€750–900/month	Small Paris agency range for this scope (estimate from published ranges, §7.4).

Payment terms: 50/50. 50% at J0, on signature (reserves the build slot and starts the audit); 50% at J5, on acceptance, before cutover. Acceptance = T01–T15 pass on staging and ASSET confirms in writing. Cutover follows management's written authorisation **and** settlement of the acceptance invoice. J6 stabilisation is covered by the build fee. Maintenance invoiced monthly from launch.

Guardrails being written into the proposal and contract (`D/18_Payment_Terms_Vetting.md`): deemed acceptance after 5 working days on staging with no written defect list; T01–T15 frozen in an annex at signature; schedule moves day for day with late client inputs, input more than 10 working days late pauses the project; changes are quoted and paid before work starts; IP in new code and design passes on full payment (data and accounts ASSET already owns stay theirs at all times); French statutory late-payment penalties and the €40 recovery indemnity (Code de commerce L441-10 and D441-5, to be verified with an accountant).

Defaults and deemed answers. Every one of the 30 questions carries a written default. Answers by Friday 6 November are built in; anything not answered follows the default. Assumptions can change by email until

signature, possibly changing price and dates.

The 12-month plan is part of the economics: the low build price is presented as "part of a 12-month managed partnership". The plan covers hosting and all tool subscriptions (opened in ASSET's name, paid by ProdCraft), security updates, backups and restore drills, monitoring, up to 5 hours of content changes a month, support Monday–Friday 9:00–18:00 Paris time, and a monthly report.

1.6 Questions for the reviewers

1. Given a competitive consultation with a procurement-style grid, does a one-person bid with this method have a realistic chance, or does "team" sink it regardless?
2. Is a deemed-acceptance clause (5 working days) likely to be accepted by a French SME's management, or will it read as hostile? (We return to this in §10.)
3. Is there anything about the client's situation (WordPress today, two domains, Traveldoo vs Wondermiles) that you think we are underweighting?

2. Requirements, complete

This section maps every requirement cell in the RFP to what we build and how acceptance is checked. It is condensed from `D/03_Functional_Breakdown.md` (64 KB, every cell, with hours and status). Status: **E** exists in our stack, **P** partial, **M** missing (new code).

2.1 Outcomes, governance and scope boundaries

#	Requirement	We build	Acceptance check	St.
A1	Qualified enquiries in three activities	Three journeys → three purpose-built forms; enquiry record with type, source, status, owner	T01–T06; monthly count by activity	P
A2	Veena + backup publish without a developer	ASSET Console; two named logins; training	T15	M
A3	Keep SEO value; current site up throughout	Parallel build on staging; old site untouched until DNS cutover; 301 map	T10; cutover log	P
A4	Integration points; launch independent of API/SSO	Connectors (email, CRM webhook, client-area link) as config	T01–T15 pass with all options off	E
A5	RACI: management, Veena, supplier, partners	RACI table in J0 pack	J0 approved	M
A6	Written approval per milestone	Deliverable list + approval email template	One approval per J0–J6	E
A7	Change control (cost, schedule, security, SEO)	Change-request form with four impact fields; hourly rate	Signed change request on file	M
A8	No production/DNS change without written authorisation	Cutover only on written go; pre-cutover checklist	Go email before DNS change	E
A9	Core independent of L3/L4; no ticketing in CMS	No booking code; quote request only	T06: enquiry saved, no ticket issued	E
A10	Exclusions; every licence, subscription and third party listed	Exclusions + third-party service table with cost and payer	Table in proposal	P
A11	French at launch; FR+EN architecture; no unapproved machine translation	`/fr/` routes, i18n strings, hreflang-ready; EN publishable only with a human-approved flag	EN routes exist, switched off	E

2.2 Mandatory audit (L0)

#	Requirement	Deliverable	St.
L0.1	CMS, versions, extensions, custom code	Audit sheet from access + crawl fingerprints	P
L0.2	Hosting, DNS, certificates	DNS/TLS inventory (records, registrar, expiry)	P
L0.3	Licences, ownership, backups, access	Account-owner register signed by ASSET	M
L0.4	Content, URLs, links	Full crawl inventory CSV (crawl→inventory tool, new)	M
L0.5	Forms, analytics, Search Console	Forms/destinations/trackers list; Search Console export	P
L0.6	Performance, compliance	Lighthouse lab baseline on 5 key pages; legal/cookie check	M
L0.7	Keep or replace CMS, with justification	Written recommendation (replace with ASSET Console; Directus as costed alternative)	P
L0.8	Workshops, journeys, discovery	One workshop of up to 2 h; journey maps for 5 journeys; backlog	E

2.3 Pages and journeys

Planned: **about 20 content pages from about 8 templates, plus 3 legal pages**, plus generated congress listing pages. ASSET supplies or approves all copy.

#	Page	We build	Acceptance
C-1	Homepage	Hero, 3 activity cards (1 click each), proof strip (approved claims only), "Upcoming congresses" block (next 6 published future events), client-area link	Each activity 1 click; block shows only published future events
C-2	Business Travel	Service template, editable FAQ, CTA → F01 "travel review"	F01 within 2 clicks
C-3	SMEs	Audience page, use cases, CTA → F01 "account/demo"	Account-request event fires
C-4	Procurement / travel managers	Policy, reporting, expenses, invoicing, audit sections; CTA → F01 "travel audit"	—
C-5	Assistance	Only services confirmed in the signed claims register	Every claim in register
C-6	Digital solutions	Approved Wondermiles text/images only; demo CTA; client-area button (config URL, click event)	T08
C-7	MICE	Hub + 3 sub-pages; CTA → F02 progressive brief	F02 within 2 clicks
C-8	Congresses	Catalogue landing (see §2.5)	T03
C-9	Agency and resources	Agency page, resources hub, article/guide templates, FAQ; team/references only with authorisation	Veena creates an article (T15)
C-10	Contact and legal	Three doors (BT/MICE/Congress); legal notices, privacy, cookies from ASSET-approved text	Each door opens the right form

#	Priority journey (RFP p3)	Path in our design	Test
J-1	SME owner	C-3 → F01 preset → enquiry type "SME account" → owner assigned → "qualified"	Walk-through in acceptance report
J-2	Travel manager	C-2/C-4 → proof → F01 "travel review"	Same
J-3	HR/comms	C-7 → F02 (3–4 steps + summary) → callback	Same
J-4	Congress participant	Catalogue → listing → F03 pre-filled → enquiry linked to congress ID → team notified	T03, T06
J-5	Existing client	"Client area" → configured external URL; no login fields on our site	T08

Design expectations: key forms within 2–3 clicks, no prospect accounts; premium understated design; authorised photography (rights note per media item); ≈ 8 templates and ≈ 15 components on a documented design-system page; wireframes, desktop and mobile mock-ups (375 and 1440), a clickable HTML prototype (our medium is code, not Figma); a **claims register** (claim, source, page, ASSET OK + date) signed before J5.

2.4 Forms, enquiries, measurement, permissions

#	Requirement	We build	Acceptance
F01	BT: company, name, business email, phone, category, volume, requirement, comments; save + acknowledge	Single-page form; durable save → acknowledgement email + on-screen confirmation	T01
F02	MICE: event type, destinations, flexible dates, travellers, services, optional budget, contact; summary before submit	3–4 step progressive form; back keeps data; review screen	T02
F03	Congress: pre-filled event, departure, destination, dates, travellers, class, contact; not one airport only	Opened from a listing with hidden congress ID + visible name; free-text departure with suggestions	T06

#	Requirement	We build	Acceptance
F04	Server-side validation, anti-spam, dedup, privacy info, send log, fallback if email fails	Schema validation in the Worker; Turnstile; dedup (same email + type + congress within 24 h → event on first record); privacy notice version stored; `send_log`; Brevo → Resend fallback → flag + retry + Console banner; durable write before "thank you"	T01–T02 with email provider deliberately broken
F05	Recipients by activity; admin with status, owner, history, CSV export	Recipient table (admin only); inbox	Routing test
F06	No personal data in URLs or analytics; events respect consent	POST-only; confirmation URL carries no data; beacon strips query strings	T09; payload crawl shows no email/phone
CRM	API/webhook, quoted separately; core works without	Outbound connector after durable save; auth as Worker secret; lookup-by-email upsert; 3 retries + dead-letter list + resend; API version pinned (option, 6 h)	Forms pass with connector off
G1–G5	Enquiry model, inbox, export, retention, routing	`enquiry` + `enquiry_event` tables; statuses; role-gated logged CSV export; proposed retention (prospects 3 years after last contact, spam 30 days; nightly purge; to verify against CNIL guidance)	T01–T02, T06, T14
H1–H4	Track CTA clicks, form starts/submits/errors, searches, listing views, account requests, client-area clicks; source/page/activity; no PII; baseline	First-party beacon → Worker → `event` table (no cookie, no IP); Cloudflare Web Analytics for page views (verified: no custom events, so the beacon is needed); Console dashboard	Payload check; baseline in J1
I1–I9	5 roles, least privilege, admin MFA, versions + restore, access logs, accidental-deletion protection	See §4.5 (permissions), §4.2 (state machines), §5 (Access)	Role × action test matrix; T05, T15

2.5 Congress catalogue (L2)

#	Requirement	We build	Acceptance
C01	Create/edit via CMS and CSV; validate; detect duplicates	Console form (dates ordered, URL valid, required fields); CSV import with dry run (§4.7)	Invalid record refused; duplicate flagged
C02	Text search; filters (discipline, country, period, city, name); ascending date; pagination; no-results	Client-side search over a pre-built JSON index (300 records); 20 per page; reset + contact on no-results	T03
C03	Publication status separate from business authorisation; nothing internal public	Editorial status on `congress`; business workflow only in the private database; public build reads a public view	T04; HTML scan finds no internal status words
C04	GM&E codes and evidence never in HTML, scripts, public responses, public exports or browser	Separate private D1 database bound only to the admin Worker; code encrypted at rest; evidence in a private R2 bucket; approver-only API; leak scanner	T05
C05	Preferential-fare claims only after human approval; no "official agency" claim without authorisation	`fare_badge` settable only by an approver at stage "approved for sale"	Badge absent until approved
C06	Official source and verification date; past-event rule and SEO	"Official website" + "Verified on dd/mm/yyyy"; proposed rule: past-edition banner, form off, link to next edition, indexable 12 months, then 301 to next edition or discipline page	T07
C07	Ticket enquiry linked to congress ID; notify; save; no issuance	F03 carries `congress_id`; type CONG; routed per F05	T06
Workflow	Detected → verified → GM&E application to prepare → submitted → code received → issuance authorised → approved for sale → archived; internal	State machine in private DB with history (§4.2)	Transition tests

#	Requirement	We build	Acceptance
Editorial	Draft → approval → publication; return to draft without data loss	Shared editorial machine (§4.2)	T04 + return-to-draft test
Data	Congress and private-authorisation field lists (RFP p5)	`congress` and `authorisation` tables with exactly those columns (§4.1)	Schema doc
Import	CSV schema, required fields, errors, duplicates, exports, change log, 300 listings	Versioned schema v1; hard/soft duplicate rules; dry run → report → confirm → import as drafts → bulk publish; batch ID in audit log	300-row dataset imported
i18n	FR/EN URLs, canonicals, hreflang	`/fr/congres/{slug}`, `/en/congresses/{slug}` (EN off)	hreflang validator

2.6 Architecture, security, data protection, handover, quality, SEO, acceptance

Area (RFP)	Requirement summary	Our answer (detail in §)
Architecture p6	Fast indexable frontend, CMS with structured catalogue, enquiry management, decoupled interfaces, diagram, data flows, dependencies, costs, reasonable alternative; secrets server-side	§5.1–5.3; Directus alternative costed §5.10
Wondermiles p6	Core: page, demo request, configurable client-area link, click measurement, no passwords. L3: SSO feasibility; API separately. No assumed Air France–KLM API	Link + event; L3a study (4 h) → L3b SSO (12 h) → L3c after study
Environments p6	Dev/staging/prod; staging restricted and not indexed; HTTPS, hardening, updates, access control, form protection, logging, security testing; no secrets in repo/browser	§5.4, §5.8
Data protection p6	Privacy info and lawful basis per form; unticked marketing boxes; tracker consent; retention, deletion, subprocessors, transfers, DPA; DSR procedure	§4.6, §5.8
Ownership p6	Accounts under ASSET control; source, repo, design files, data, media handed over; non-transferable licences listed; exports, backups, transfer	§6.7
Quality p7	Responsive at 320/375/768/1440 + real devices; LCP ≤ 2.5 s, INP ≤ 200 ms, CLS ≤ 0.1 at p75 where field data exists + lab reports; WCAG 2.2 AA; backups RPO 24 h / RTO 8 business hours; measurable SLA	§5.6, §5.7, §9
SEO p7	Crawl, inventory, decide per URL; 301/308 without chains or blanket-to-home; editable meta, headings, URLs, structured data, sitemap, robots, canonicals; staging not indexable; reports; Search Console after launch	§4.8
Content p7	ASSET validates services, claims, images and rights; supplier states counts, writing vs migration, revisions, translation	20 + 3 pages; 300 listings; migration + light edit; 2 rounds per stage; translation excluded
Maintenance p7	Security fixes, updates, backups, monitoring, availability, out-of-scope, on-call; illustrated admin guide; deploy/restore/export procedures; account inventory; secure secret transfer; train Veena + backup	§6.7, §7.6

Acceptance tests (RFP §7) and how we run them.

Test	RFP scenario	Our test (dataset → expected)	Automated?
T01	BT form: clear errors, saved once, routed, acknowledged	Invalid → inline errors; valid → 1 row; repeat → 0 new rows + event; recipient email; email provider broken → fallback	Yes (Playwright + D1 assertions)
T02	MICE form: same	Same + summary screen + back keeps data	Yes
T03	Congress search, filters, sort, no-results	300-row dataset; 10 queries with expected result sets	Yes
T04	Draft not public before approval	Draft slug → 404 on prod; absent from sitemap and search index	Yes
T05	GM&E code invisible to public and unauthorised roles	Leak scanner over all public output with a seeded fake code (proves detection); role matrix: only approver/admin read the vault	Yes
T06	Ticket enquiry with pre-filled event saved and notified	F03 from listing → row with `congress_id` → CONG recipient email	Yes

Test	RFP scenario	Our test (dataset → expected)	Automated?
T07	Past congress under approved rule	End date in past → banner, form off, link; redirect rule unit-tested	Yes
T08	Client-area link, no local password storage	Link to configured URL; schema check: no password column anywhere	Yes
T09	Refusing trackers works and is changeable	Refuse → no tracker requests in network log; change → takes effect	Yes
T10	Priority old URLs redirect correctly	Every priority URL → exactly one 301 → 200	Yes
T11	Keyboard and screen reader on critical journeys	axe: 0 serious violations + manual script (NVDA/VoiceOver) on 5 journeys	Partly (manual script)
T12	Responsive + performance	4 widths screenshots per template + Lighthouse lab within targets	Yes (+ eye review)
T13	Successful test restoration	Restore last night's dump into a fresh D1; timed against RTO	Scripted, run by hand
T14	Readable, documented export	Export opened in a spreadsheet; columns match the doc	Partly
T15	Veena publishes then edits without a developer	Veena alone, with the guide: creates an article, publishes, edits, restores a revision	Manual (observed)

2.7 The 30 questions and their defaults

We sent 30 questions in 7 groups (MECE; coverage proof in `D/07_Question_Coverage_Matrix.md`). Eight are "Answer first" (Q1, 2, 3, 5, 6, 9, 15, 18). Every question has a written default that applies if unanswered by 6 November. The full list with defaults is **Appendix A**. The defaults that most shape the design:

Q	Default that shapes the build
Q3	Management approves each stage within 3 working days; silence = deemed approval of design/content stages; launch always needs written go; acceptance window 5 working days against T01–T15 only.
Q6	New site on `asset-voyagesdaffaires.com`; `assetvoyages.com` redirects (web only, email untouched).
Q7	No trackers carried over; cookie-free analytics + first-party event beacon.
Q9	ASSET writes new copy; we migrate up to 20 existing pages + 3 legal, light edit only.
Q15	All enquiries to one shared mailbox (direction@assetvoyages.com) until ASSET names others; no reply-time promise.
Q17	One spreadsheet of up to 300 congresses in our template; one import + error report; no research of events.
Q18/Q20	No fare code or fare wording anywhere until ASSET confirms GM&E in writing; only "request a quote".
Q21	Past congress stays online as past edition, quote button off.
Q22	One request = one group, one departure city, flights only; extras in free text.
Q23	One "Client login" button to today's Traveldoo URL, editable in admin.
Q26	One-time code to named work email, then a second factor (authenticator app or security key); or the client's Microsoft 365 / Google Workspace with its own MFA.
Q27	Database in the EU; US providers under DPAs; no security questionnaire included.
Q28	Two editors (Veena + backup); management reads enquiries and gives final congress approval; only Veena and management see GM&E codes.
Q30	Support Mon–Fri 9:00–18:00 Paris; target site back within 8 business hours after a serious incident on our side; hosting-provider outages excluded.

2.8 What the clarifications reply (31 October) promised

The client asked seven clarification questions. Our reply (`D/01c_…`) committed us to the following, all of which the proposal must now carry:

Promise	Where it lands in this plan
Standard open-source stack; no proprietary framework; maintainable by another developer from the repo and docs	§5, §6.7
A fixed list of editable **section types**; what stays with a developer (new section types, design system, integrations, platform)	§4.1 (`block` types), §6.3
Source repo in an organisation in ASSET's name, handed over in full with all rights at completion; admin guide; runbook; full export runnable by ASSET; defined **transfer package** with a stated duration of transfer assistance	§6.7
2 revision rounds per design stage and per content stage	§7.2
A one-page **prototype table**: every visible element marked included / optional / illustration only	§6.1 (contract C0)
A congress **spreadsheet template** with a dry-run validation before the real import; data-quality checks (required fields, dates, duplicates, broken official links) and a rejection report; no event research	§4.7
Fixed price for core; monthly plan with measured commitments; hourly rate and change procedure	§7
50% at J0, 50% at J5 acceptance before cutover; free correction of any in-scope T01–T15 failure; dated schedule; symmetric lateness rules	§1.5, §7
Wondermiles: link at launch; feasibility study, then integration quoted after	§2.6
Optional asks: "Site by ProdCraft" footer credit; a LinkedIn post after launch (strikable, never a condition)	Proposal clause

2.9 Questions for the reviewers

1. Is any RFP cell missing, or mapped to an acceptance check that would not convince a sceptical client?
2. T11, T13, T14 and T15 are partly manual. Is that acceptable, or would you insist on more automation?
3. Our deemed-approval defaults (Q3) are aggressive. Do they protect the schedule enough to justify the friction?

3. What exists today

3.1 The workspace

ProdCraft's work runs from one repository (`deb-antigravity-claude-workspace`) organised in three layers:

1. **Directives** (`directives/{category}/`): Markdown standard operating procedures (goal, inputs, scripts, outputs, edge cases). They are updated with every failure ("self-annealing").
2. **Orchestration**: the AI session reads the directive and calls scripts in order. It does not hand-process anything a script can do.
3. **Execution** (`execution/{category}/`): deterministic Python and Node scripts; shared modules in `execution/modules/`; secrets in the environment only.

The point of the split is that business logic is deterministic and tested; the probabilistic part (the model) only routes and drafts. You should judge whether that holds for this project.

3.2 Reusable assets, with paths

Asset	Path	What it gives this project
Astro + Cloudflare template	`execution/templates/web_app_astro_cf/` (`README.md`, `HARDENING.md`, `HANDOFF.md`)	Astro 5 SSG, Pages Functions, `_headers` with CSP/HSTS/nosniff/frame-deny, FR-default i18n with `/en/` mirror, a11y baseline, KV rate limit, `/api/health` (upstream status, secret presence, build SHA), Vitest + Playwright + Python acceptance gate + front-door synthetic, CI (SAST → unit → build → preview → acceptance → front-door), scaffold script.
Contracts-first pattern	`execution/personal_workflows/prodcraft_medspa/CONTRACTS.md`	Binding layout, interfaces, data classes, error channel and testing rules written before any code; every script runnable with `--mock`. Also an approval pipeline (draft → review → approved) we port to D1.
Static-site validator	`execution/gtm_client_workflows/<job-board build>/validate_site.py`	Pre-ship validation of a rendered static site (links, structure, assets). Basis for the SEO lint and leak scanner.
Worker pattern for forms	`…/<job-board build>/worker/`	Cloudflare Worker with `wrangler.toml`; form intake pattern.
Concept-site skill	`.claude/skills/site-redesign/SKILL.md`, `reference/build_rules.md` (88 rules "paid for once")	Prospectus-style concept, scroll-scrubbed film, deploy, eye review. Used to build the ASSET concept.
Functional suite + site_check	`D/research/functional.mjs`, `site_check.mjs`	Playwright assertions across desktop, Pixel 7, iPhone 13, reduced motion; zero console errors; zero third-party requests; overflow and tap-target checks.
CSP-faithful local server	`D/research/serve_csp.mjs`	Serves the site with the real `_headers` CSP so tests see production headers.
Enforcement hooks	`docs/reference/enforcement.md`, `.githooks/`, `execution/infrastructure/workspace_sast.py`	Pre-commit (blocks untracked deploy-target code), pre-push SAST (blocks HIGH/CRITICAL), Stop-hook verdict check. `--no-verify` requires a logged reason.
Audit stack	`.claude/memory/panel_roster.md`, `.claude/rules/`	11-lens panel pass, project-expert panel, front-door synthetic, acceptance gate, adversarial loop. Used three rounds on the outgoing pages.
Human-eye gate	`human-eye-test` skill	Screenshots every page/state/viewport, reviewer agents read each image against a defect checklist, verdict with evidence.

Asset	Path	What it gives this project
Proposal system	`execution/gtm_client_workflows/proposal_system/`	JSON → DOCX/PDF proposal with itemised HT/TVA/TTC.
Jev	`directives/infrastructure/jev.md`	Pinned classify/score/gate model via OpenRouter, used for the L4 confidence gate.
Python hardening rules	`.claude/rules/python-hardening.md`, `python-execution.md`, `security.md`, `testing.md`	UTF-8 subprocess, no secrets in code/logs, test tiers.

Prior production builds we draw on (anonymised): a public job-board build with listings, filters and a 3,047-check validation suite; two live bilingual FR/EN sites with forms, moderation and a GDPR data-subject-request flow; an approval pipeline with an R2-backed preview worker. None of these is a travel or MICE site. We have **no travel/MICE reference**, which the client's "verifiable references" criterion will expose.

3.3 What the concept already proves

The concept (`D/site/`, deployed noindex at the URLs in §1.4) is a static site, not the product. It proves the front-end craft and the Congress journey, nothing about the back-end.

Evidence	Result	Source
Functional suite	65/65 at the last run (28 Oct, recorded in `D/research/functional.json`); round 3 documented 62/62 before three assertions were added	`D/research/functional.json`, `D/15_Audit_Round3_Project_Experts.md`
site_check	PASSED on 4 pages × 4 contexts (desktop, Pixel 7, iPhone 13, reduced motion)	`HANDOFF.md` v2.4
axe-core (WCAG 2.0/2.1/2.2 A+AA)	0 violations on 4 pages × 2 viewports (rounds 1, 2 and 3)	`D/09_`, `D/12_`, `D/15_`
Bundle	≈ 108 KB (index 33 + CSS 29 + JS 46, of which film 22); zero third-party JS; self-hosted fonts	`HANDOFF.md`
Film	30 s scroll-scrubbed hero, rendered by our own pipeline (Chromium + ffmpeg, 24 fps); canvas fallback; reduced-motion poster	`D/research/render_film.mjs`
Catalogue demo	12 fictional listings; search, filters, combined filter, no-results, reset, pagination, listing dialog, F03 prefill with fr-FR dates	functional suite
Console mock	Static: tiles, Pages, Congresses (one draft visible only in the console), Enquiries (Nouvelle / Qualifiée / Devis envoyé / Gagnée), GM&E `<details>` explanation	`D/site/console/`
Confidentiality	0 matches for other clients' names in `site/`; asserted in the suite	`HANDOFF.md`
Honesty	Every quoted claim verbatim from live pages re-fetched 28 Oct; two flagged quotes re-verified with URLs; no prices, percentages, testimonials or codes	`HANDOFF.md` v2.1
Review	Three internal audit rounds (11 lenses + 5 experts each); final verification PASS (34/34 fixes)	`D/08_`–`D/15_`

Known limits of that evidence: the sandbox could not screenshot `*.pages.dev`, so the live-viewport trust gate was not run on production; live checks were HTTP 200, CSS hash match and CSP header confirmation. The eye review of v2 was done by the build worker itself in one round, then an independent reviewer returned NOT SHIP and every item was fixed (v2.1).

3.4 What is missing (the honest list)

None of these exist as code today. Each must be built, tested and documented before the acceptance test that depends on it.

#	Missing piece	Needed by	Est. hours
1	Console editor: structured block editor, preview, publish trigger	T15, A2	14
2	Roles + MFA: Cloudflare Access in front of `/admin`, 5-role permission matrix in every route, break-glass	I1, I2, T05	10
3	D1 schema + migrations (public and private databases)	everything	in modules
4	Versions and restore (`revision` snapshots), soft delete with 30-day trash	I5, I7, T15	7
5	Audit log (user, action, object, time; 12 months)	I6	3
6	CSV import with dry run, hard/soft dedup, rejection report, batch ID	C01, N3–N7	5
7	Enquiry back-office: inbox, statuses, owner, history, logged export, routing	F05, G1–G5	12
8	Backups (nightly D1 export → R2, off-platform weekly copy) + restore drill	T13, RPO/RTO	3 + drill
9	Uptime monitoring + status page + dead-man alarm on backups	SLA	1.5
10	Core Web Vitals (Lighthouse CI) and axe gates in CI per template	T11, T12	in QA
11	Crawl → URL inventory → redirect map generator + chain detector	L0.4, S1–S2, T10	8
12	GM&E leak scanner over all public output (HTML, JS, JSON, sitemap, exports)	T05	2.5
13	Media library (R2 upload, required alt text, rights note, resizing)	I4, D3	4
14	First-party event beacon + dashboard	H1–H4	3.5

3.5 Capability matrix

Capability	Status	Lift path
Static public site, FR default, hreflang-ready	EXISTS	Scaffold from the template; add ASSET templates.
Security headers, CSP, HSTS	EXISTS	Template `_headers`; tighten for Console.
Forms: validation, Turnstile	EXISTS	Reuse; add dedup and fallback.
Form durable save + two-provider email fallback	PARTIAL	KV save exists; add D1 save, `send_log`, Brevo → Resend adapter, retry queue.
Consent banner and GDPR DSR flow	EXISTS	Port DSR from KV/Supabase pattern to D1.
Structured data, sitemap, robots, canonicals	EXISTS	Add `Event` schema for congresses.
Redirects	PARTIAL	We have generated 302 maps; switch to 301, add chain test and generator.
Listings with filters	PARTIAL	Job-board pattern; add period filter and search index.
Approval pipeline	PARTIAL	Port the draft → review → approved pattern to D1 state machines.
Admin auth	PARTIAL	Basic Auth today; replace with Access + roles.
Block editor, media, versions, soft delete, audit log	MISSING	New, built as a reusable "Console" package with ASSET as first tenant.
D1 data layer	MISSING	Drizzle schema + migrations; no prior D1 project.
Encrypted private vault	MISSING	New; AES-GCM with key in a Worker secret.
Backups and restore drill	MISSING	New cron Worker + runbook + timed drill.
Monitoring and status page	PARTIAL	Health endpoint exists; add external probes.
Lighthouse and axe in CI	MISSING (as gates)	axe used ad hoc in audits; wire both into CI with thresholds.
Crawl → redirect map	MISSING	New script + directive + `--mock` test.
AI ingestion (L4, optional)	PARTIAL	Jev and OpenRouter exist; queue, eval set, pinning are new.

Roughly 40% of the scope by hours rests on EXISTS rows; the rest is PARTIAL or MISSING. The largest unmeasured line is the Console (≈ 44 h estimated, never timed on this stack).

3.6 Questions for the reviewers

1. Is "40% proven" a fair characterisation from the matrix, or are we flattering ourselves?
2. Which MISSING item would you build first as a spike to de-risk the estimate? (Our answer is the block editor + publish rebuild loop.)
3. Is there an off-the-shelf component you would use instead of building any MISSING row?

4. System design

4.1 Domain model

Two D1 databases with separate bindings: **`public_db`** (content, catalogue, enquiries, events; readable by the build and the form Worker) and **`vault_db`** (GM&E authorisations; bound only to the admin Worker). All IDs are ULIDs. Every mutable table carries `created_at`, `updated_at`, `deleted_at` (soft delete), `created_by`, `updated_by`.

```
public_db
  user(id, email, display_name, role, active, last_login_at)
  page(id, slug, locale {fr|en}, title, meta_title, meta_description, template,
       status {draft|in_review|published|archived}, published_at, approved_by,
       translation_of, human_translated:bool, version)
  block(id, page_id, position, type, data_json, version)
     type ∈ {hero, text, image_text, cards, list, faq, cta, quote_claim,
             congress_strip, contact_doors}
  media(id, r2_key, mime, width, height, alt_text NOT NULL, rights_note NOT NULL,
        rights_expires_on, uploaded_by)
  claim(id, text, source_url, page_id, approved_by, approved_on)      -- claims register
  congress(id, title, slug, discipline, country_iso2, city, venue, organiser,
           start_date, end_date, timezone, official_url, verified_on, language,
           editorial_status {draft|in_review|published|archived},
           visibility {listed|unlisted}, fare_badge:bool, next_edition_id,
           import_batch_id, version)
  enquiry(id, type {BT|MICE|CONG|SME_ACCOUNT|DEMO}, created_at, source_utm_json,
          landing_path, referrer_domain, company, contact_name, email, phone,
          payload_json, congress_id NULL, status, owner_id, privacy_notice_version,
          marketing_optin, marketing_optin_at, dedup_key, purge_after)
  enquiry_event(id, enquiry_id, actor_id, kind, note, at)
  send_log(id, enquiry_id, provider {brevo|resend}, recipient_hash, status, error, at)
  recipient_rule(id, enquiry_type, email, backup_email)
  revision(id, entity, entity_id, version, snapshot_json, actor_id, at)
  audit_log(id, actor_id, action, entity, entity_id, ip_trunc, at)
  event(id, name, path, activity, utm_source, utm_medium, utm_campaign,
        referrer_domain, props_json, day)                -- no cookie, no IP, no PII
  import_batch(id, filename_hash, rows_total, rows_ok, rows_rejected,
               rows_flagged, dry_run:bool, actor_id, at, report_r2_key)
  setting(key, value)                                    -- client-area URL etc.

vault_db
  authorisation(id, congress_id, application_date, channel, code_ciphertext,
                code_iv, evidence_r2_key, conditions, stage, approver_id,
                valid_from, valid_to, version)
  stage_history(id, authorisation_id, from_stage, to_stage, actor_id, note, at)
```

`congress_id` in the vault refers to `public_db.congress.id` by value; there is no cross-database join path in code that the public build or the form Worker can execute.

4.2 State machines

Editorial (pages and congresses).

```
          submit (contributor+)          approve+publish (editor+)
  draft ──────────────────────► in_review ──────────────────────► published
    ▲                              │                                  │
    └──────── return to draft ─────┘──────── unpublish (editor+) ─────┘
                (no field lost; new revision)                        │
  published ── archive (editor+) ──► archived ── restore (editor+) ──► draft
```

Rules: every transition writes a `revision` and an `audit_log` row. Only `published` rows enter the public build. An EN page can only reach `published` if `human_translated = true`. Editors publishing their own draft is allowed (two-person rule is an option, not default: the client has two editors).

GM&E internal workflow (vault only).

```
detected → verified → application_to_prepare → application_submitted
        → code_received → issuance_authorised → approved_for_sale → archived
```

Transition	Guard
→ verified	`official_url` and `verified_on` present on the congress
→ application_submitted	`application_date` and `channel` present
→ code_received	code (encrypted) + evidence file + validity period present; approver/admin only
→ issuance_authorised	named approver sign-off
→ approved_for_sale	approver only; unlocks `fare_badge` option on the public congress
→ archived	read-only thereafter; code retained to `valid_to` + retention period
any → previous	approver/admin only, with a mandatory note

Enquiry.

```
new → contacted → qualified → quoted → won | lost
  └──────────────────────────────────────────► spam (purged after 30 days)
```

Any transition records actor, time and note in `enquiry_event`. Owner can be set at any state. A duplicate submission (same email + type + congress within 24 h) appends an event to the first record instead of creating a row.

4.3 Invariants

These are properties the system must hold at all times. Each has a test.

#	Invariant	Enforced by	Test
I-1	No GM&E code, evidence or vault stage ever appears in any public byte (HTML, JS, JSON index, sitemap, RSS, public CSV, API response, error page)	Structural: vault is a separate database bound only to the admin Worker; public build has no binding to it. Scan: leak scanner with a seeded canary code across the full build output and public API responses, in CI	T05; CI fails on any match
I-2	No personal data in URLs, analytics events or logs	POST-only forms; beacon whitelist of properties; search text dropped if it matches email/phone patterns; log redaction; IP truncated in audit log	Payload crawl in T09; log grep in CI
I-3	Nothing reaches production except through the editorial state machine	Build reads `status = published` only; no direct-publish API	T04; unit tests on the build query
I-4	An enquiry is durably stored before the user sees "thank you"	Handler writes D1 (or KV fallback) and only then returns 200; email is sent asynchronously via queue	T01 with D1 and email deliberately failed
I-5	No password is stored for the client area	No password column; client area is an external link	T08 schema check
I-6	Every mutation is attributable	`audit_log` written in the same transaction as the mutation	Unit tests per route
I-7	A fare badge is never shown without `approved_for_sale`	Badge flag write path checks vault stage via admin Worker	T05 dataset
I-8	Imports are idempotent	Hard-duplicate key; batch ID; dry run writes nothing	Import the same file twice → 0 new rows

4.4 Roles

Role	Who (default Q28)	Purpose
Technical admin	ProdCraft (later ASSET's chosen developer)	Everything, including settings, recipients, users, break-glass

Role	Who (default Q28)	Purpose
Editor	Veena, backup editor	Create, edit, publish pages and congresses; import; manage enquiries
Contributor	Optional	Drafts only
Commercial viewer	Management, sales	Read enquiries, export, dashboard
Congress/fare approver	Management (and Veena, per Q28)	Vault read/write, GM&E stages, `approved_for_sale`, fare badge

Note the tension: Q28's default says "only Ms Khatri and management can see GM&E codes; the backup editor cannot". Veena is therefore Editor **and** Approver; the backup editor is Editor only. Roles are a set per user, not a single value.

4.5 Permissions matrix

Action	Admin	Editor	Contributor	Viewer	Approver
Create/edit draft page or congress	✓	✓	✓	—	—
Submit for review	✓	✓	✓	—	—
Publish / unpublish / archive	✓	✓	—	—	—
Restore revision / restore from trash	✓	✓	own drafts	—	—
Hard delete	✓	—	—	—	—
Upload media	✓	✓	✓	—	—
CSV import (dry run / commit)	✓	✓	—	—	—
Public catalogue export	✓	✓	—	✓	✓
Read enquiries	✓	✓	—	✓	—
Change enquiry status / owner	✓	✓	—	—	—
Export enquiries (logged)	✓	✓	—	✓	—
Read vault / GM&E code	✓	—	—	—	✓
Advance GM&E stage, set fare badge	✓	—	—	—	✓
Edit recipients, settings, client-area URL	✓	—	—	—	—
Manage users and roles	✓	—	—	—	—
Read audit log	✓	own actions	—	—	✓ (vault)

The matrix is data (`permissions.ts`), enforced by one middleware on every admin route, and tested exhaustively (5 roles × every route × allowed/denied) in CI. Cloudflare Access gates the hostname; the app decides authorisation from the Access JWT's email mapped to `user.role`.

4.6 Data retention and export

Data	Retention (proposal, ASSET to approve)	Deletion
Prospect enquiries	3 years after last contact (based on CNIL prospect guidance; to verify)	Nightly purge job on `purge_after`
Spam	30 days	Purge job
Won clients	Per ASSET's own records policy	Manual
Audit log, Access logs	12 months	Purge job
Send log	12 months, recipient stored as hash	Purge job
Revisions	All, or last 50 per entity (to decide)	—
Vault	Until `valid_to` + agreed period	Approver action, logged
Backups	D1 Time Travel 30 days; nightly dumps 30 days; 12 weekly off-platform copies	Lifecycle rules

Data	Retention (proposal, ASSET to approve)	Deletion
Events	Aggregated daily; no PII	Raw rows 13 months

Export: one command (and a Console button for admins) produces a ZIP with every table as CSV (UTF-8, documented columns) and JSON, plus the R2 media tree and a manifest with checksums. The vault exports separately, encrypted, admin only. **DSR procedure**: search by email across `enquiry`, `enquiry_event`, `send_log` (by hash); export or delete; log the request.

4.7 CSV import model

Element	Rule
Schema	Versioned (`v1`); columns = RFP congress fields; ISO dates (`YYYY-MM-DD`), ISO 3166-1 alpha-2 country, UTF-8, `;` or `,` auto-detected
Required	title, discipline, country, city, start_date, end_date, official_url, verified_on, language
Row errors	Coded (`E01 missing_required`, `E02 bad_date`, `E03 end_before_start`, `E04 bad_url`, `E05 unreachable_url`, `E06 bad_country`, …)
Hard duplicate	normalised title + start_date + city → rejected
Soft duplicate	same normalised title, same year → flagged for a human
Flow	Upload → dry run (writes nothing) → report (OK / rejected / flagged, downloadable CSV) → confirm → import as drafts with batch ID → editor bulk-publishes
Idempotency	Re-importing the same file creates nothing new

4.8 i18n and SEO migration model

i18n. French is the default at `/` (or `/fr/`, to decide with the redirect map, since today's URLs have no locale prefix). English lives under `/en/`, built but not published until the option is bought. Strings in typed locale files; content per locale as separate `page` rows linked by `translation_of`. Each page emits `<link rel="canonical">` to itself and `hreflang` pairs (`fr`, `en`, `x-default`) only when both versions are published. No machine-translated content can be published (I-3 + `human_translated`).

SEO migration.

```
crawl old site ─► URL inventory (status, title, canonical, inlinks, GSC clicks)
     ─► decision per URL: retain | merge | redirect | remove (ASSET approves priority URLs)
     ─► mapping sheet ─► generated _redirects (301) ─► chain detector + no-home-blanket check
     ─► staging test: every old URL → one 301 → 200
     ─► cutover checklist (noindex removed on prod, sitemap submitted)
     ─► weekly Search Console + 404 report through J6, then monthly
```

Staging is `noindex` (header and robots) and behind Access. Removed URLs return 410 where intentional. Congress pages emit schema.org `Event` with the real organiser (to check against Google's event structured-data policy).

4.9 Questions for the reviewers

1. Two D1 databases for vault isolation: is that sufficient, or would you put the vault on a different account or provider entirely?
2. Is the permission model (role set per user, one middleware, exhaustive matrix test) adequate for a 5-user system, or over-engineered?
3. Does any invariant lack a test that would actually fail if it were broken? (I-1 is the one we worry about: free-text fields.)
4. Would you store revisions as full snapshots (our plan) or diffs?

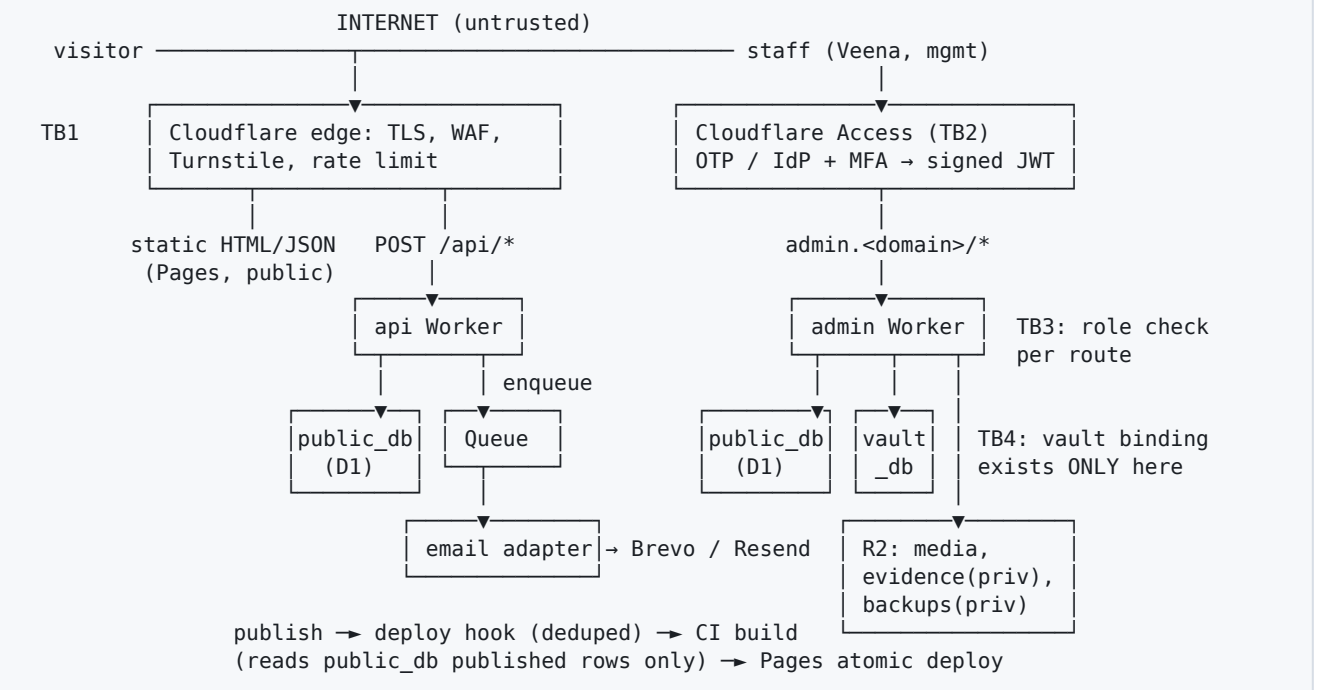
5. Architecture

5.1 Components

Component	Role	Why this
Cloudflare Pages (static assets)	Public site, pre-built Astro HTML, JSON search index	Fast globally, no origin to patch, free static requests
Workers (modular monolith)	`api` Worker: forms, beacon, health. `admin` Worker: Console API (behind Access). `cron` Worker: backups, purge, retry.	One codebase, three entry points; shared modules; no network hops between services
D1 (jurisdiction EU)	`public_db`, `vault_db` per environment	SQL, Time Travel 30 days, EU jurisdiction set at creation (verified 28 Oct)
R2	Media (public bucket via Worker), evidence (private bucket), backups (private bucket)	No egress fees
Cloudflare Access	Gate on admin and staging hostnames; one-time PIN or client IdP; MFA	No public admin login page
Turnstile	Anti-spam on forms	Free, no cookies for challenge
Queues	Email sending and retries; rebuild trigger de-duplication	Decouples "thank you" from email delivery
Cron Triggers	Nightly backup, purge, dead-man heartbeat	Built-in
Email adapter	Brevo (primary, French company) → Resend (fallback)	Two providers behind one interface
AI adapter (L4 only)	OpenRouter + Jev, pinned model ID, prompt hash, schema-bound output	Option; never publishes
GitHub (org in ASSET's name)	Repo, CI (Actions), Renovate/Dependabot	Ownership from day one
External monitor	UptimeRobot (free tier) probes + status page	Independent of Cloudflare

Language and libraries: TypeScript throughout; Astro for pages; Console UI in Preact or web components (open decision, §10); Zod for validation at every boundary; Drizzle for schema and migrations; Playwright, Vitest, axe-core, Lighthouse CI for tests.

5.2 Topology and trust boundaries



Boundary	Crossing	Control
TB1 Internet → edge	All visitor traffic	TLS, HSTS, CSP, WAF managed rules, Turnstile, per-IP rate limit on `/api/*`
TB2 Internet → admin	Staff only	Access policy by named email; OTP or IdP; MFA; session length 12 h
TB3 Admin Worker → data	Every Console request	Verify Access JWT (aud + signature), map email → roles, permission middleware, Zod input validation
TB4 Vault	Only the admin Worker has the `vault_db` and private R2 bindings	Code encrypted with AES-GCM; key is a Worker secret; approver/admin only
TB5 Build → public	CI build	Build query selects published rows; leak scanner on output before deploy
TB6 Workers → third parties	Email, monitor, AI	Secrets in Worker secrets; minimum data (no PII to AI; recipient hash in logs)

5.3 Data flows

Flow	Steps
Enquiry	Browser POST → Turnstile verify → Zod → dedup key → D1 insert (fallback KV if D1 errors) → 200 "thank you" → queue message → email adapter (Brevo; on failure Resend; on double failure flag + retry every 15 min + Console banner) → `send_log`
Publish	Editor approves → state change + revision + audit → deploy hook (deduplicated: many presses = one build) → CI builds from published rows → leak scanner + SEO lint → Pages atomic deploy → "live in about N min" (N to measure)
Import	Upload CSV to admin Worker → parse + validate + dedup in dry run → report to R2 → confirm → transactional insert as drafts with batch ID
Authorisation	Approver opens vault → reads/advances stage → `stage_history` + audit; badge flag write checks stage
Backup	Nightly cron → D1 export (both DBs) → R2 private bucket (dated) → weekly copy to an off-platform store (provider TBD) → heartbeat to monitor (dead-man alarm if missed)
Measurement	Page view: Cloudflare Web Analytics (cookie-free). Events: beacon POST with whitelisted properties → `event` table → daily aggregates

5.4 Environments

Env	Host	Data	Access	Indexing
dev	localhost (Wrangler, local D1/R2)	Seed + fixtures; fake GM&E codes	Developer	n/a
staging	`staging.<domain>` + `admin.staging.<domain>`	Own D1/R2; anonymised copy of prod or seed	Access (named emails)	`X-Robots-Tag: noindex`, robots disallow
prod	`<domain>`, `admin.<domain>`	Production	Public / Access	Indexable after cutover checklist

Same code, different bindings (`wrangler.toml` environments). Secrets per environment. Preview deployments per pull request run against staging data.

5.5 Deployment and rollback

- **Atomic**: Pages deploys are immutable; a deploy switches all at once. Workers deploy with versioned uploads.
- **Rollback**: Pages instant rollback to the previous deployment; Workers rollback to previous version; D1 schema migrations are forward-only and additive (expand → migrate → contract across two releases) so code rollback never meets an incompatible schema. Data rollback via Time Travel to a timestamp.
- **Cutover (J5)**: lower DNS TTL 48 h before; deploy prod; run the checklist (redirects, noindex off, sitemap, forms to real recipients, monitors); switch DNS on written go and cleared payment; keep old host available for 30 days for DNS revert.

5.6 Backups and restore

Layer	Mechanism	RPO	Coverage
1	D1 Time Travel (30 days on Paid, verified 28 Oct)	Minutes	Both DBs
2	Nightly SQL export → R2 private bucket, 30 dated copies	24 h	Both DBs
3	Weekly copy of layer 2 + media to an off-platform store, 12 kept	7 days	DBs + media
4	Git repo (code, config, migrations)	per commit	Code

Restore drill: monthly in the plan, and at J5 for T13. Script: create a fresh D1, import last night's dump, point a staging Worker at it, run the smoke suite, record elapsed time. RTO target 8 business hours (RFP); the drill measures it. The drill has **never been run on this stack**.

5.7 Observability

- External probes (UptimeRobot, 5-minute interval): home, a congress page, `/api/health` (checks D1 read, queue depth, secret presence, build SHA), admin login page reachable.
- Status page (UptimeRobot free tier).
- Dead-man heartbeat from the backup cron; missing heartbeat alerts.
- Error channel: Worker exceptions and failed jobs post `service / environment / error / count` to one channel (email + messaging) owned by ProdCraft.
- Workers observability logs (no PII); `send_log` failures surface as a Console banner for Veena.
- Monthly report: availability, backups, restore drill result, enquiries by activity, Search Console errors, patch log.

5.8 Security

Control	Implementation
Transport	TLS, HSTS (preload after stabilisation)
Headers	CSP `default-src 'self'`, no inline script, `frame-ancestors 'none'`, `nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy` minimal
Admin exposure	No public admin; Access on hostname; JWT verified in-app (defence in depth)
MFA	Access one-time PIN alone is a single factor (possession of the mailbox), so it is not MFA. Default (Q26): client IdP with enforced MFA; if ASSET has none, a Cloudflare-supported IdP with TOTP/passkey. Open: which IdP ASSET uses.
Least privilege	Five roles, matrix-tested; Cloudflare API tokens scoped per job; GitHub branch protection
Secrets	Worker secrets only; pre-commit and pre-push SAST block secrets; bundle scan for keys; rotation at handover
Input	Zod at every boundary; parameterised queries via Drizzle; CSV parsing with size and row caps
Abuse	Turnstile, rate limit, dedup
Vault	Separate DB, encryption at rest with app key, approver-only, leak scanner
Dependencies	Renovate PRs, monthly patch window, critical within 2 business days, `npm audit` in CI
Testing	SAST pre-push, dependency audit, OWASP ZAP baseline on staging, role matrix, leak scanner
Data protection	DPA (ProdCraft as processor); subprocessor register (Cloudflare US/EU DPA + SCCs/DPF, Brevo FR, Resend US, UptimeRobot, GitHub)

5.9 Failure modes and fallbacks

Failure	Effect	Fallback	Detection
D1 unavailable	Forms cannot write	Write to KV backup store; replay job; user still gets "thank you" (I-4)	health check, error channel
Brevo fails	No notification	Resend; then flag + 15-min retry + Console banner	`send_log`
Both email providers fail	Team not notified	Enquiry is saved; banner; daily digest retry	send_log, alert

Failure	Effect	Fallback	Detection
Access outage (happened 12 Jun 2025, ~2h28)	Admin unreachable	Public site unaffected; editing waits; break-glass CLI for emergencies	monitor
Cloudflare global incident (e.g. 18 Nov 2025, ~2h10)	Site down	None on-platform; status page; excluded from SLA (Q30)	external probe
Bad deploy	Broken pages	Instant rollback	front-door synthetic
Bad migration	Data inconsistency	Forward-fix or Time Travel restore	migration tests on staging copy
Accidental deletion	Content lost	Soft delete + trash 30 days + revisions	—
Leak of a code into free text	Exposure	Leak scanner fails the build before deploy	CI
Rebuild storm (many publishes)	Build queue	De-duplicated deploy hook	queue depth
Spam wave	Inbox noise	Turnstile + rate limit + spam status	counts
Founder unavailable	No support	Runbook a stranger can follow; repo and accounts in ASSET's name; named backup developer (not yet arranged)	—

5.10 Alternatives considered

Directus (headless CMS) + same Astro front end. Pros: mature editor, roles, revisions and media out of the box; less custom code (perhaps −25 to −30 h on the Console). Cons: needs a server and Postgres (≈ €10–30/month VPS range, estimate), patching and uptime of that server become ours, ≈ 16 h setup (≈ €1,100 at €70/h), the vault invariant must then be enforced inside Directus permissions rather than structurally, and a second runtime to hand over. We present it as the costed alternative and do not recommend it, mainly because of the vault and operational load. **This is the decision we most want you to challenge.**

WordPress + ACF (keep the current platform): lowest switching cost for editors; but plugin attack surface, PHP hosting, and the GM&E isolation is harder to prove. Kept as the "retain" option the L0 audit must evaluate honestly.

Why not microservices. Five users, ≈ 300 listings, low traffic. Separate services would add network failure modes, deploy coordination and monitoring cost with no scaling benefit. A modular monolith (one repo, three Worker entry points, shared typed modules, adapters at the edges) keeps boundaries in code and ships from one pipeline. Strictly, three Workers deploy as three versioned uploads; CI deploys them in a fixed order from one commit, and the forward-only schema rule (§5.5) keeps a partial deploy safe.

5.11 Questions for the reviewers

1. Is Cloudflare-only (no SLA on Workers/D1 at our plan level) an acceptable concentration risk for this client?
2. Is the KV fallback for enquiries worth its complexity, or would you accept a visible error when D1 is down?
3. Would you choose Directus here? What would change your mind either way?
4. Is the backup design adequate for RPO 24 h / RTO 8 business hours? What would you add?

5.12 Engineering specifics (added at pre-review QA)

Platform limits below are from Cloudflare's public docs as we understand them on 31 Oct 2026; each is marked to re-verify at J0 because they change.

Topic	Position	Status
Load assumed	Order of magnitude only: ≤ 5 staff users, ≈ 300 listings, low thousands of visits/day, tens of enquiries/day. No traffic data from ASSET yet.	Open: obtain 12 months of analytics at L0 to replace these guesses.
D1 size and concurrency	Workload is ≈ MBs; D1 per-database limit is 10 GB (Paid). A D1 database executes queries serially on one primary, so throughput depends on query time; at tens of writes/day this is not a constraint. Public reads hit Pages static output, not D1.	Re-verify limits at J0.

Topic	Position	Status
Workers CPU for CSV import	300 rows parse and validate in well under a second of CPU; Workers Paid allows 30 s CPU by default (configurable higher). Cap: 5 MB / 2,000 rows per file; larger files rejected with a message. Insert in D1 `batch()` chunks inside one batch ID so a failed chunk rolls back that import.	Cap values are our proposal.
Media pipeline	Upload via admin Worker to R2 (type sniffed, size cap 10 MB, EXIF stripped). Responsive variants either at build time (Astro image, sharp in CI) or via Cloudflare Image Transformations on the R2 origin. Default: build-time variants (no per-transform cost).	Open: confirm image counts at L0.
Search and pagination	Catalogue is ≈ 300 rows: the build emits a JSON index and the browser filters and paginates client-side (as the concept does). No SQL LIKE or FTS5 on the public path. The Console list uses SQL with `LIMIT/OFFSET` and indexed filters; FTS5 only if listings exceed ≈ 5,000.	Decided default.
Caching / freshness	No ISR: the site is fully static and every publish triggers a deduplicated rebuild (§5.3). HTML is served with short edge cache and revalidation; hashed assets are immutable. Freshness after publish = build time (to measure, target < 5 min).	Measure in walking skeleton.
Draft preview	Preview builds per draft are not planned; the Console renders a draft with the same Astro components server-side behind Access, `noindex`.	Open: confirm effort fits inside Console core hours.
Editor concurrency	Optimistic locking: each entity carries `version`; a save with a stale version returns 409 and shows the other editor's change. No real-time co-editing.	Decided default.
i18n slugs	Slugs are per locale (`page.slug` unique per `locale`), linked by `translation_of`; French slugs keep today's URLs where the redirect map retains them.	Decided default.
Rate limiting on forms	Turnstile on every form plus a per-IP limit on `/api/*` (Workers rate-limiting binding or WAF rule, e.g. 10 posts / 10 min / IP) and a body size cap.	Thresholds to tune on staging.
Access session	Session 12 h for admin, re-auth for vault actions if the IdP supports it; revocation by removing the email from the policy and revoking sessions.	Open: vault step-up depends on IdP.
D1 migration rollback	Migrations are forward-only (expand/contract). Each migration is applied first to a staging copy of prod; rollback of a bad one is a forward-fix or Time Travel restore to the pre-migration bookmark recorded by CI.	Decided default.
Secret rotation	Inventory of secrets (vault key, email API keys, Turnstile, deploy hook) in the runbook with owner and rotation steps; rotate at handover and annually. Vault key rotation needs re-encryption: store a key ID with each ciphertext so old and new keys coexist during rotation.	Key-ID column added to design.
GDPR data-subject flows	Access, rectification, erasure via the DSR procedure in §4.6, answered within one month; erasure also covers backups by expiry (30 days / 12 weeks), which the privacy notice must state.	Open: ASSET to name the DSR contact.
Audit-log tamper evidence	Append-only table (no update/delete grants in code), each row stores a hash of the previous row (hash chain), and the nightly backup exports it off-platform, so silent edits are detectable. Not tamper-proof against a platform admin.	Decided default.
Backup encryption	R2 encrypts at rest; the weekly off-platform copy is encrypted client-side (age or GPG) before upload, key held by ASSET admin and ProdCraft. Vault dump is encrypted separately.	Open: off-platform provider not chosen.
Test data	Seed fixtures with fictional listings and fake GM&E codes; staging uses seed data by default, an anonymised prod copy only with ASSET's approval. No real codes outside prod.	Decided default.

6. Build plan

6.1 Contracts before code

Before the first line of product code (week 1), we write and freeze a `CONTRACTS.md` for the project, following our existing pattern. It is the reference every module and every AI-assisted implementation session is held to.

Contract	Content
C0 Scope	The prototype table (every visible element: included / optional / illustration), section-type list, page and listing counts, T01–T15 annex
C1 Schema	Drizzle schema for both databases (§4.1), migration policy (expand/contract)
C2 API	Every route: method, path, role, Zod input/output, errors
C3 State machines	Transitions, guards, side effects (§4.2) as a typed table, tested
C4 Invariants	I-1 … I-8 with their tests (§4.3)
C5 Adapters	`EmailProvider`, `Store`, `Clock`, `AIProvider` interfaces, each with a mock
C6 CSV v1	Columns, formats, error codes, duplicate rules
C7 Events	Beacon event names and whitelisted properties
C8 Ops	Backup, restore, export, deploy, rollback commands

6.2 Walking skeleton (week 1–2)

A thin end-to-end slice deployed to staging, before any feature depth: one Astro page from one `block` → one form (F01) → D1 insert → queue → email via the adapter → Console behind Access listing that enquiry → publish button triggering a rebuild → nightly backup → restore into a fresh D1 → CI with leak scanner, axe and Lighthouse on that one page. It exists to measure the unmeasured: the rebuild time N, the Access + JWT path, the D1 export size and restore time, and the real speed of Console development.

6.3 Modules

#	Module	Content	Est. hours	Owner
M1	Audit and discovery (L0)	Crawl tool, inventory, account register, baseline, workshop, architecture doc	12	Debanjan
M2	Design system and mock-ups	Tokens, ≈ 15 components, 8 templates, wireframes, mock-ups 375/1440, prototype	24	Debanjan
M3	Public pages	≈ 20 pages + 3 legal from templates, content integration	20	Debanjan
M4	Forms F01–F06	Three forms, validation, Turnstile, dedup, durable save, email adapter, fallback	12	Debanjan
M5	Enquiry back-office	Inbox, statuses, owner, history, logged export, routing	12	Debanjan
M6	Measurement + GDPR	Beacon, dashboard, consent, legal pages, DSR	8	Debanjan
M7	Console core	Access + roles, block editor (fixed section types), media, revisions + restore, soft delete, audit log, publish pipeline	44	Debanjan
M8	Catalogue (public)	Search index, filters, pagination, listing template, past-event rule, `Event` schema, sitemap	14	Debanjan
M9	Catalogue (admin) + vault	Congress form, CSV import, exports, editorial + GM&E state machines, encryption, leak scanner	18 (21 on detailed count)	Debanjan
M10	SEO migration	Redirect generator, chain test, Search Console	12	Debanjan
M11	Infrastructure	Envs, CI, backups, drill, monitoring, break-glass	12	Debanjan

#	Module	Content	Est. hours	Owner
M12	QA and acceptance	T01–T15, a11y manual, CWV lab, ZAP, acceptance report	22	Debanjan (+ independent reviewer agents)
M13	Handover	Guide, runbook, inventory, training ×2, transfer package	10	Debanjan
M14	Project management	Weekly written updates, milestone packs, revisions, change control	18	Debanjan
	Total core		**238** (+ 48 contingency = 286)	

Every module is one person. The "team" is the founder plus AI-assisted implementation and independent reviewer agents. There is no second human engineer today.

6.4 Test strategy

Tier	Tool	What	When
Unit	Vitest	State machines, permissions matrix, dedup, CSV parser, redirect generator, encryption round-trip	Every push
Integration	Vitest + Miniflare / local D1	Routes against real local D1, adapters mocked and real	Every push
E2E	Playwright	Journeys J-1…J-5; Console flows; T01–T10 automated	Every preview deploy
Acceptance	T01–T15 suite + report generator	Evidence (screenshots, DB rows, logs) compiled into the acceptance report	J3, J4, J5
Accessibility	axe-core in Playwright; manual NVDA/VoiceOver script	0 serious violations; manual 5 journeys	Every preview; manual at J3, J5
Performance	Lighthouse CI (lab) per template	LCP ≤ 2.5 s, CLS ≤ 0.1, TBT budget as INP proxy	Every preview
Leak test	Scanner over build output + public API responses with seeded canary	0 matches, canary found in the vault fixture	Every build (blocks deploy)
Security	SAST hooks, `npm audit`, ZAP baseline	No HIGH/CRITICAL	push; ZAP at J3, J5
Restore drill	Script + stopwatch	Elapsed ≤ RTO; smoke suite green on restored DB	J5, then monthly
Front-door synthetic	Bash probe against live URL	5 consecutive green days before calling it "live"	From cutover
Human-eye gate	Screenshot every page/state/viewport, reviewer reads each	PASS or defect list	J2, J3, J5

6.5 CI gates

A pull request cannot merge unless all pass: typecheck → lint → unit → integration → build → leak scanner → SEO lint (one H1, titles, canonicals, hreflang, no internal status words) → preview deploy → E2E → axe (0 serious) → Lighthouse (thresholds per template) → front-door on preview. Pushes also run workspace SAST (blocks HIGH/CRITICAL). Main is protected; deploy to prod only from tagged releases.

6.6 Definition of done per milestone

Milestone	Done when
J0	Signed proposal and deposit cleared; RACI; access inventory sent; schedule with dates; repo and Cloudflare account created in ASSET's name; written approval
J1	Crawl inventory with decision column; account register; baseline (CWV lab, trackers, forms, Search Console); architecture doc; backlog; risk register; walking skeleton on staging; written approval

Milestone	Done when
J2	Wireframes + mock-ups for 8 templates at 375 and 1440; prototype link; design-system page; claims register started; ≤ 2 revision rounds; written approval
J3	All L1 pages on staging from Console content; F01/F02 pass T01–T02; tracking events verified; axe 0 serious; Lighthouse within targets; Console editing usable by Veena; written approval
J4	300 listings imported (or ASSET's file, with rejection report); T03–T08 pass; vault + leak test green; written approval
J5	Redirect map approved and T10 green; T01–T15 all pass; acceptance report delivered; training session 1 done; restore drill timed; rollback plan; written acceptance (or deemed after 5 working days); payment cleared; written go; DNS cutover
J6	4 weeks: daily checks, Search Console weekly, fixes, outstanding-items list closed, training session 2, handover pack complete (repo, accounts, secrets rotated, exports), closure document

6.7 Handover as a product

The client's essential conditions include supplier handover. We treat it as a feature with its own acceptance:

Item	What ASSET gets	Test
Media upload	Upload with required alt text and rights note	Veena uploads during T15
CSV dry run	Self-serve import with report	Veena imports a 10-row file
One-click export	ZIP of all data + media + manifest	T14
Restore	Runbook + script; drill record	T13
Per-screen help	Short help panel on every Console screen	Review
Generated guide	Illustrated admin guide generated from the Console's own screenshots	Veena follows it in T15
Training	Two remote sessions (Veena, backup editor), recorded; second session 4 weeks after launch	Attendance
Runbook	Deploy, rollback, restore, export, rotate secrets, add a user; written for a stranger at 6 a.m.	A person not involved follows it
Inventory	Every account, owner, plan, cost, renewal date	Signed
Transfer package	Repo, docs, inventory, secrets transfer via password manager, a defined period of transfer assistance (to set in the proposal)	Checklist

Operations without us. Nightly backup, monthly restore drill, external monitor and dependency PRs run on schedules, not on the founder's memory. If ProdCraft stops, the site keeps running on ASSET's accounts; what stops is patching and support.

6.8 Questions for the reviewers

1. Is a walking skeleton in weeks 1–2 realistic alongside the L0 audit, or does it delay J1?
2. Which CI gate would you drop as cost without benefit at this scale? Which is missing?
3. Is our definition of done for J3 strong enough to stop us declaring the Console done before Veena can use it?
4. How would you test "a stranger can follow the runbook" credibly?

7. Effort, timeline, price

7.1 Hours

Two estimates exist; both are **estimates by analogy** with past builds, not measured on this stack.

Work item	`effort_estimate.md`	`03_` reconciled
L0 audit	8	12
Design system, mock-ups, prototype	16	24
Public pages	24	20
Forms F01–F06	12	12
Enquiry back-office	12	12
Console core	40	44
Catalogue public	14	14
Catalogue admin + vault	18	18 (21 detailed)
SEO migration	8	12
GDPR + consent + measurement	6	8
Infrastructure	10	12
QA and acceptance	16	22
Handover	10	10
Project management	25	18
Core total	**≈ 220**	**238**
Contingency 20%	44	48
Planning figure	**≈ 265**	**286**

Options (hours): English activation 8 · CRM connector 6 · Wondermiles feasibility 4 / SSO 12 · AI ingestion 16. The largest single uncertainty is the Console (40–44 h): it has no prior code and is where a one-person estimate is most likely to be wrong by a factor.

7.2 Included quantities

Up to 20 content pages from ≈ 8 templates + 3 legal pages; up to 300 listings imported from ASSET's spreadsheet; copy supplied or approved by ASSET, migrated with light editing; 2 revision rounds per design stage and per content stage; 2 training sessions; 4-week stabilisation.

7.3 Calendar

Assumptions: signature and deposit by Fri 13 Nov 2026; start Mon 16 Nov; approvals within 3 working days; Christmas slow period 21 Dec–1 Jan, no launch in it. Lean pace ≈ 35 h/week; conservative ≈ 22 h/week plus realistic client delays. **These are estimates.** We intend to contract the conservative dates.

Milestone	Lean (≈ 9–10 weeks to launch)	Conservative (≈ 13–14 weeks)
J0 Kickoff approved	Fri 20 Nov 2026	Fri 20 Nov 2026
J1 Audit approved	Wed 2 Dec	Wed 2 Dec
J2 UX/UI approved	Wed 16 Dec	Fri 8 Jan 2027
J3 Core site on staging	Fri 15 Jan 2027	Fri 5 Feb
J4 Congresses	Fri 22 Jan	Fri 19 Feb
J5 Acceptance + cutover	Week of 25 Jan	Fri 12 Mar
J6 Stabilisation ends	Fri 26 Feb	Fri 9 Apr

Building in 4–5 weeks is only possible by cutting scope (for example, Console editing limited to text and images; GM&E workflow as statuses only).

7.4 Price options and market evidence

Option	Build HT	Plan HT	Effective build rate (265 h)
Lean	€4,000	€600/mo, 12 min	≈ €15/h
Recommended	**€7,500**	**€600/mo, 12 min**	≈ €28/h
Fair solo	€9,500–12,000	€600–750	≈ €36–45/h
Market (small agency)	€18,000–25,000	€750–900	≈ €68–94/h

Market evidence (`D/research/market_pricing_paris_2026.md`; mostly search-engine summaries, some second-hand; **verify before quoting**):

Evidence	Figure	Source
Experienced Paris full-stack freelance day rate	≈ €520–600/day (median ≈ 525–560)	Malt barometer 2026, TJMetre 2026, Freeland 2026
Small agency day rate (5–15 people)	€550–800/day	La Fabrique du Net 2026 (summary)
Custom site with back-office and APIs	from €8,000	Agence2web 2026
Medium web app	€20,000–50,000	Seedweb 2026
Maintenance, multi-page corporate WordPress	€100–350/month	Make Different, Ellebay 2026
Out-of-contract hourly	€60–150 HT	Ellebay, Make Different 2026

At 265 h, even the recommended price is ≈ 5% of a freelance day-rate equivalent (265 h ≈ 38 days × €550 ≈ €21k). The plan fee is above the WordPress maintenance range because it includes hosting, tools, SLA, backups, drills and 5 h of changes.

7.5 Three-year total cost of ownership (core only, HT)

Option	Build	Plan 36 months	3-year total	TTC (20% VAT)
Lean	4,000	21,600	25,600	30,720
Recommended	7,500	21,600	29,100	34,920
Market low	18,000	27,000	45,000	54,000
Market high	25,000	32,400	57,400	68,880

The RFP asks for this figure explicitly and says not to count a service twice; tool costs are inside the plan.

7.6 Running costs (paid by ProdCraft inside the plan; accounts in ASSET's name)

Item	Monthly (estimate, Oct 2026 prices)	Source
Workers Paid (incl. D1, Queues, Time Travel 30 d)	$5 ≈ €4.3	Cloudflare pricing pages, 28 Oct 2026
D1, R2, Access (≤ 50 users, unverified on Cloudflare's page), Turnstile, Web Analytics	€0 at this size	Cloudflare docs
Brevo (300/day free; Starter if needed)	€0–9	Brevo
Resend (fallback, free tier)	€0	Resend
UptimeRobot (free; Solo optional)	€0–10	UptimeRobot
Off-platform backup store	TBD (not yet chosen or priced)	—
Domain	≈ €9–32/year	estimate
AI helper (L4 only)	€5–20	own estimate

Item	Monthly (estimate, Oct 2026 prices)	Source
Total	**≈ €5–15/month; up to ≈ €25 with paid monitoring**	

7.7 Questions for the reviewers

1. Is €7,500 + €600/month a credible bid, or is it so low it signals risk to a procurement panel? Would you go to €9.5k+?
2. Is the 20% contingency enough for a one-person build with a never-built Console?
3. Is contracting the conservative calendar the right call in a competitive bid where a rival may promise 10 weeks?

8. Risk model and grading

8.1 Complexity

A weighted function-point style score: each module's share of effort (weight) times a complexity rating from 1 (trivial, done many times) to 10 (novel, hard to test). Ratings are our judgement. The original table was produced in session; this is a reconstruction that reproduces the stated score.

Module	Weight	Complexity (1–10)	Contribution	Why
Public pages	0.15	3	0.45	Template, done before
Forms + dedup + fallback	0.10	6	0.60	Async email, two providers, durable save
Enquiry back-office	0.08	5	0.40	CRUD + history
Console editor, media, versions	0.22	8	1.76	New; UX for non-developers; rebuild loop
Roles, MFA, audit	0.10	7	0.70	Access JWT + matrix
Catalogue public	0.08	4	0.32	Pattern exists
Catalogue admin + import	0.10	7	0.70	Dedup, dry run, idempotency
GM&E vault + workflow	0.07	8	0.56	Encryption, isolation, leak proof
SEO migration	0.05	7	0.35	Unknown URL count; client approval
Infra, backups, monitoring	0.05	7	0.35	Never run restore drill on D1
Total	**1.00**		**≈ 6.2 / 10**	

8.2 Confidence model

We model on-time, in-scope delivery to J5 acceptance as the probability that **none** of a set of independent risks materialises badly enough to break the contracted date or scope:

$$P(\text{success}) = \Pi_i \, (1 - r_i)$$

where r_i is the residual probability, after mitigation, that risk *i* causes a contract-level miss. Independence is an assumption and is optimistic: late client inputs and founder availability are correlated through the calendar. The r_i values are our judgement; the table reconstructs the session's model and reproduces its stated totals (≈ 0.73 conservative, ≈ 0.55 lean).

Please put your own number in the last column.

#	Risk	Mitigation	r (conserv.)	r (lean)	Your r
R1	Client inputs late (content, CSV, approvals, access)	Defaults; deemed approval; day-for-day shift; pause clause; weekly written chase	0.08	0.14	
R2	Founder availability (illness, overload; single point of failure)	Conservative calendar; runbook; repo in client's name; no backup developer yet	0.07	0.11	
R3	Console scope overrun	Fixed section types; walking skeleton measures speed in week 1–2; scope-cut list ready	0.03	0.08	
R4	Current-site access / DNS / domain ownership blocked	Ask at J0 (Q4, Q5); what-to-ask template; parallel build	0.03	0.05	
R5	GM&E vault design flaw or leak	Structural isolation; encryption; leak scanner with canary; role tests	0.01	0.01	
R6	SEO migration loses a critical URL	Crawl + GSC data; chain test; T10; weekly monitoring	0.02	0.03	
R7	Platform limitation (D1, Access, Workers) discovered late	Skeleton exercises every binding early	0.01	0.02	
R8	Notification failure in production	Two providers; durable save; banner	0.01	0.01	

#	Risk	Mitigation	r (conserv.)	r (lean)	Your r
R9	Acceptance dispute / test redefinition	T01–T15 frozen in annex; deemed acceptance; defects only against tests	0.01	0.03	
R10	CSV data quality from client	Template; dry run; rejection report; research excluded	0.01	0.03	
R11	Backup/restore fails at drill	Drill in skeleton and at J5; Time Travel as second layer	0.01	0.02	
R12	Scope creep	Change control paid first	0.01	0.04	
	P = Π(1 − r)		**≈ 0.735**	**≈ 0.552**	

Reading: on the conservative calendar we estimate roughly a 3-in-4 chance of hitting J5 on the contracted date and scope; on the lean calendar, about even. The two largest residuals (R1, R2) are not engineering risks. The model does not cover the risk of **losing the bid**, nor post-launch defects.

8.3 The 11-lens panel pass on this plan

Each lens is an analytical stance, named after a public figure's known emphasis (`.claude/memory/panel_roster.md`). They are not quotes and not endorsements.

1. Karpathy (measurement). The plan is better instrumented than most: every acceptance test has a dataset and an expected result, and the KPIs in §9 name a tool. But the inputs to the plan are not measured. The 238/286 h estimate is by analogy; the Console has never been timed; the rebuild delay N and restore time are unknown. *Honest gaps:* no enquiry baseline yet; field CWV may never exist for a site this size; the risk probabilities are judgement, not data. The walking skeleton is the first real measurement and should re-base the estimate at J1.

2. Cherny (tooling craft). Contracts before code, adapters with mocks, idempotent imports, deterministic gates in CI: this is the right shape for AI-assisted building. *Honest gaps:* the crawl→redirect tool, leak scanner, Lighthouse/axe gates, backup cron and restore drill do not exist; each needs a directive and a `--mock` test before it can be trusted. The weekly-update script is assumed, not built.

3. Dario Amodei (honesty, legal exposure). The plan avoids unprovable claims: no fare wording without written GM&E confirmation, claims register, verbatim quotes only. *Honest gaps:* CNIL retention guidance and Google's Event structured-data policy are cited from memory; the DPA is not drafted; whether prior builds were commissioned or concept work must be stated precisely in references; "deemed acceptance" must be worded so it is not misleading.

4. Anthropic research (rigour). Definitions are mostly precise (duplicate keys, state guards, thresholds). *Honest gaps:* the duplicate rule, past-event rule and retention periods are proposals awaiting approval; the L4 eval set does not exist; model and prompt pinning for L4 is designed but not implemented; the confidence model assumes independence it does not have.

5. Hormozi (offer, economics). Risk reversal runs both ways (free fixes against T01–T15; deemed acceptance). *Honest gaps:* at €7.5k the build is ≈ €28/h; the economics only work if the 12-month term holds and the Console is reused for the next client. There is no travel/MICE reference, so perceived likelihood rests on the concept site.

6. Saraev (automation boundaries). Human decisions are kept where the client feels them: approvals, publication, GM&E stages, acceptance. L4 is a supervised scheduled skill, not an agent. *Honest gaps:* there is no error channel yet for scheduled jobs; the redirect map and CSV import must be checked by an ASSET human before they count.

7. Daniela Amodei (people, trust). Accounts in the client's name, transparent costs, strikable credit request. *Honest gaps:* no named holiday or sickness cover; support is business hours only; the reply-time promise to enquirers is unknown (Q15); the 12-month minimum must be visible, not buried.

8. Sutskever (failure modes). The vault is protected structurally, not by convention. *Honest gaps:* the leak scanner only catches codes it knows; a code typed into a congress description would be caught only because all public output is scanned for every stored code, which must be implemented and tested exactly that way. L4 hallucination bounds are designed, not tested.

9. Murati (user experience). The concept proves the public journey on phones. *Honest gaps:* the MICE progressive brief and listing hierarchy are unvalidated with real buyers; the Console UX for a non-technical editor is the least proven part of the whole plan; real-device testing depends on which devices the founder owns.

10. Brockman (reliability). Atomic deploys, instant rollback, Time Travel, dead-man alarm. *Honest gaps:* the second backup provider is not chosen or priced; an Access outage takes the admin down (accepted); there is no on-call; the restore drill has never been run on this stack.

11. Hassabis (long-horizon). The plan compounds only if the Console is built as a product with ASSET as its first tenant and ASSET-specific code kept separate. *Honest gaps:* there is no plan yet for the second tenant; reuse value is asserted, not demonstrated.

8.4 The five-expert view

Expert	View on this plan	Main concern
Senior Product Manager	Requirements are fully mapped; defaults turn ambiguity into decisions	The client may experience defaults and deemed approvals as pressure; proposal tone matters
Senior Product Designer	Concept is strong; design system scope is right-sized	Console design for Veena is under-specified compared with the public site
Senior Solution Architect	Modular monolith, vault isolation and EU D1 are sound for the scale	Single-vendor concentration; second backup location undecided; Directus trade-off should be tested, not argued
Senior UX/UI Designer	Journeys are short (≤ 2–3 clicks); axe-clean concept	Progressive MICE form and editor need usability testing with real users
Senior Full-Stack Developer	Stack is standard and maintainable by others	44 h for a block editor with versions, media and preview is optimistic; spike it first

8.5 Questions for the reviewers

1. Please re-score R1–R12 in the table and add any risk we missed.
2. Is the complexity score's weighting of the Console (22% weight, 8/10) right?
3. Is P = Π(1 − r) a reasonable model here, or would you use something else (for example a reference-class forecast)?

9. KPIs and acceptance metrics per stage

Each KPI has a target, a measurement method, a tool and an owner. "Baseline" means measured, not targeted.

9.1 J0 Kickoff

KPI	Target	Method / tool	Owner
Access inventory completeness	100% of listed accounts (domain, DNS, hosting, email, GA, GSC, GBP) with named owner and access status	Account register; count filled / total	Debanjan, Veena
Accounts created in ASSET's name	100% (GitHub org, Cloudflare, Brevo, monitor)	Register + screenshots	Debanjan
Deposit cleared	Yes before work	Bank	Debanjan
Schedule approved	Written	Email	Management

9.2 J1 Audit and discovery

KPI	Target	Method / tool	Owner
URL inventory	Count of crawled URLs (baseline) with 100% assigned a decision	Crawl tool + decision sheet	Debanjan
Search Console coverage	Top pages by clicks covered in the map: 100% of URLs with ≥ 1 click in 16 months	GSC export	Debanjan
Baseline CWV (lab)	LCP, CLS, TBT on 5 key pages recorded	Lighthouse	Debanjan
Tracker inventory	Count of trackers and tags found	Network log crawl	Debanjan
Forms inventory	Count and destinations	Crawl + manual	Debanjan
Skeleton measures	Rebuild time N, restore time, Console velocity recorded	Stopwatch, CI logs	Debanjan
Estimate re-baselined	Yes, with delta vs 286 h	Spreadsheet	Debanjan

9.3 J2 UX and UI

KPI	Target	Method	Owner
Mock-ups approved	8/8 templates	Approval email	Management
Revision rounds used	≤ 2 per stage	Change log	Debanjan
Click depth to each form	≤ 2–3 from home	Click-count table	Debanjan
Claims register	Started; every claim on mock-ups listed	Register	Veena

9.4 J3 Core website

KPI	Target	Method / tool	Owner
Pages built	n/total (target 23/23)	Console page list	Debanjan
Forms pass	T01, T02 green	Playwright suite	Debanjan
Accessibility	axe 0 serious/critical on all templates	axe-core in CI	Debanjan
Performance (lab, mobile profile)	LCP ≤ 2.5 s, CLS ≤ 0.1, TBT ≤ 200 ms (INP proxy) per template	Lighthouse CI	Debanjan
Events	All 8 event types fire with correct properties, 0 PII	Beacon test + payload grep	Debanjan
Editor usable	Veena edits one page alone	Observed session	Veena

9.5 J4 Congresses

KPI	Target	Method / tool	Owner
Listings imported / rejected / flagged	Counts reported; rejected rows returned with error codes	Import report	Debanjan, Veena

KPI	Target	Method / tool	Owner
Dedup rate	Hard duplicates rejected 100%; soft flagged	Import report on a seeded file	Debanjan
Leak test	0 matches across all public output; canary detected	Leak scanner	Debanjan
T03–T08	100% pass	Suite	Debanjan
Role matrix	100% of role × route cells as specified	Matrix test	Debanjan

9.6 J5 Pre-launch

KPI	Target	Method / tool	Owner
T01–T15	100% pass, evidence in report	Acceptance report	Debanjan; Veena confirms
Redirect coverage	100% of priority URLs; ≥ 95% of all inventoried URLs with a decision implemented; 0 chains; 0 blanket-to-home	Redirect test on staging	Debanjan
Restore drill	RTO measured and ≤ 8 business hours; smoke suite green	Drill script + stopwatch	Debanjan
Lighthouse	Performance ≥ 90, Accessibility ≥ 95, SEO ≥ 95 per template (lab)	Lighthouse CI	Debanjan
Security	ZAP baseline: 0 high; SAST 0 HIGH/CRITICAL	ZAP, SAST	Debanjan
Launch blockers	0 (security, data loss, failed form, code exposure, missing critical redirect)	Go/no-go checklist	Management

9.7 J6 Stabilisation (4 weeks)

KPI	Target	Method / tool	Owner
Uptime	≥ 99.5% measured by external probe	UptimeRobot	Debanjan
Search Console errors	No new 404 on mapped URLs; coverage errors trending to 0	GSC weekly	Debanjan
Enquiries/day	Baseline by activity (no target until agreed post-audit)	D1 counts	Veena
Time-to-first-edit by Veena	First solo publish ≤ 3 working days after launch	Audit log	Veena
Outstanding items	0 open at J6 close	List	Debanjan
Front-door synthetic	5 consecutive green days	Probe	Debanjan

9.8 Post-launch (monthly, in the plan)

KPI	Target	Method / tool
Availability	≥ 99.5% monthly, excluding provider-wide incidents (stated in SLA)	External probe
Backup success	100% of nightly jobs; 0 missed heartbeats	Cron log + dead-man alarm
Restore drill	Monthly, pass, time recorded	Drill log
Change SLA	Requests within 5 h/month delivered within an agreed number of working days (to set)	Ticket log
Security patches	Critical within 2 business days; others monthly	Patch log
Enquiries by activity	Reported, with source and conversion events	D1 + beacon dashboard
CWV field data	Reported if CrUX publishes it	CrUX

9.9 Questions for the reviewers

1. Which KPI here is a vanity metric? Which business KPI is missing?
2. Is 99.5% the right promise for a Cloudflare-only stack with no platform SLA?
3. Is TBT an acceptable lab proxy for INP?

10. Open decisions and asks for the reviewers

10.1 Open decisions

#	Decision	Options	Our lean	What would change it
D1	Build price	€4,000 vs €7,500 (vs ≥ €9,500)	€7,500 + €600/mo × 12	Evidence that procurement discounts low bids as risky
D2	Console	Build (custom on Workers + D1) vs Directus	Build	A credible estimate that the custom Console exceeds ≈ 70 h, or vault isolation achievable in Directus with equal confidence
D3	Console UI	Preact vs web components (Lit or vanilla)	Undecided; Preact for velocity, web components for zero-framework longevity	Your view on maintainability by a third party
D4	Database	D1 (EU) vs external Postgres (e.g. EU-hosted managed)	D1	Concerns about D1 maturity, export, limits or lock-in
D5	Deemed acceptance	5 working days after staging delivery	Keep, worded politely	Evidence it costs us the bid
D6	Off-platform backup store	Not yet chosen	Choose before J1	Your recommendation
D7	Backup developer	None today	Name one before signature	Whether you think the bid is viable without one
D8	Locale prefix for French	`/` vs `/fr/`	Decide from crawl	Old URL structure

10.2 What we ask you to tell us

1. The single change that would most increase the chance of on-time, in-scope delivery.
2. The single change that would most increase the chance of winning the bid.
3. Anything in this pack you believe is wrong, not just risky.
4. Anything you would refuse to sign off on in a design review.

10.3 Questions for the reviewers

1. D2 and D4: if you were the sole engineer, which would you choose and why?
2. Is there any part of the plan you would cut entirely?

10.4 Scoring sheet

§	Section	Score 1–10	Comment
1	Business context		
2	Requirements, complete		
3	What exists today		
4	System design		
5	Architecture		
6	Build plan		

7	Effort, timeline, price		
8	Risk model and grading		
9	KPIs per stage		
10	Open decisions		
—	**Overall: would you fund this plan?**		

Reviewer name: _____ Date: _____ Time spent: _____ h

Appendix A. The 30 questions with defaults

Source: `D/01b_Questions_source.md`. "AF" = Answer first. Defaults apply if not answered in writing by Friday 6 November 2026.

Q	Question (short)	Default if unanswered
1 AF	Proposal due date, decision date, launch constraints	Proposal 24–48 working h after answers or by 10 Nov; start within 5 working days of signature; launch ≈ 12 weeks after start; no launch 21 Dec–1 Jan
2 AF	Budget range or cap	Quote as set out in proposal; options priced separately
3 AF	Approvers per stage; days per approval	Management approves in writing within 3 working days; silence = deemed approval of design/content; launch needs written go; acceptance 5 working days on T01–T15 only
4	Who maintains today's site; contract/notice	Nothing limits the project; ASSET arranges handover
5 AF	Accounts in ASSET's name; owner of new accounts	ASSET gives access at kickoff; new accounts in ASSET's name, management owner, Veena admin
6 AF	Which domain(s)	`asset-voyagesdaffaires.com`; `assetvoyages.com` redirects (web only)
7	Read-only GA/GSC; trackers and campaigns to keep	Plan from our own crawl; no trackers carried over; cookie-free counting; ads excluded
8	Selectour requirements	Logo and membership line as today
9 AF	Who writes copy; page counts	ASSET writes new copy; we migrate ≤ 20 pages + 3 legal, light edit, within 2 rounds
10	Brand guidelines	Keep logo and colours; short style guide
11	Photos, logos, testimonials, figures, named team	Only what is on today's site and confirmed in writing; illustrations; no named team
12	SME simplified offer	Page explains and collects requests; no prices
13	Assistance services, hours, numbers	24/7 wording as today; phone only once confirmed
14	English journeys, timing, translator	French only at launch; English option; ASSET pays translation
15 AF	Recipients per enquiry type; reply time	One shared mailbox (direction@assetvoyages.com); no reply time promised
16	CRM / newsletter tools	None; site enquiry list + Excel export; no marketing tick box
17	10 sample rows; sources; yearly volume	One spreadsheet ≤ 300 rows in our template; one import + error list; no research
18 AF	GM&E participation; code mechanics	No fare code or fare wording until confirmed in writing; vault holds code, evidence, validity
19	Who does each GM&E step; final approver	Veena moves steps; management approves for sale
20	What to show publicly about fares	Only "request a quote"
21	Past congress: archive or remove	Stays as past edition without quote button; link to next edition
22	Quote scope: multiple departures, hotel, transfers	One group, one departure, flights only; extras in free text
23	Wondermiles vs Traveldoo; other client tools	One "Client login" to Traveldoo URL, editable; no SSO; no other tools
24	Wondermiles contact; what may be shown; docs access	Text only, no logo/screenshots until approved; no technical link-up
25	AI option first use	Finds new congresses on official sites for human review; nothing auto-published

Q	Question (short)	Default if unanswered
26	Microsoft 365 / Google Workspace	One-time code to work email + second factor; or client IdP with its MFA
27	EU/France data; security questionnaires; data contact	DB in EU; US providers under DPAs; no questionnaire included; management handles DSRs
28	Admin users and access	Two editors; management reads enquiries and approves congresses; only Veena and management see GM&E codes
29	Expected monthly changes	Up to 5 h/month in the plan; no carry-over
30	Support hours; tolerable interruption	Mon–Fri 9:00–18:00 Paris; site back within 8 business hours after a serious incident on our side; provider outages excluded

Appendix B. Glossary

Term	Meaning
MICE	Meetings, Incentives, Conferences and Exhibitions: corporate group events
GM&E	Air France–KLM Global Meetings & Events: event codes giving attendees discounted fares; agencies apply per event
Selectour Affaires	French network of business-travel agencies, of which ASSET is a member
Wondermiles / Traveldoo	Online booking tools used by corporate clients; the RFP names Wondermiles, today's site links Traveldoo
SSO	Single sign-on (SAML or OpenID Connect)
IdP	Identity provider (Microsoft 365, Google Workspace)
MFA / OTP / TOTP	Multi-factor authentication / one-time PIN / time-based authenticator code
RPO / RTO	Recovery point objective (max data loss, 24 h) / recovery time objective (max time to restore, 8 business hours)
CWV: LCP, INP, CLS	Core Web Vitals: Largest Contentful Paint, Interaction to Next Paint, Cumulative Layout Shift
TBT	Total Blocking Time, a lab metric correlated with INP
p75	75th percentile of field (real-user) measurements
CrUX	Chrome UX Report, Google's public field-data set
hreflang	HTML annotation linking language versions of a page
Canonical	The preferred URL for a page, declared to search engines
301 / 308	Permanent HTTP redirects
D1	Cloudflare's hosted SQLite database; Time Travel = point-in-time restore
R2	Cloudflare object storage, no egress fees
Workers / Pages	Cloudflare serverless compute / static hosting
Access	Cloudflare Zero Trust login gateway
Turnstile	Cloudflare's privacy-friendly CAPTCHA alternative
ULID	Sortable unique identifier
Zod / Drizzle	TypeScript validation library / TypeScript ORM and migrations
SAST	Static application security testing
ZAP	OWASP Zed Attack Proxy, an automated web-security scanner
DPA / SCCs / DPF	Data processing agreement / EU standard contractual clauses / EU-US Data Privacy Framework
CNIL	France's data-protection authority
DSR	Data subject rights request (GDPR access, erasure, etc.)
HT / TVA / TTC	Excluding VAT / VAT / including VAT
RACI	Responsible, accountable, consulted, informed
Jev	ProdCraft's pinned classify/score/gate model routing (OpenRouter)
Front-door synthetic	A probe that exercises the live production URL as a user would

Appendix C. File index of the deliverable folder

`D/ = deliverables/asset_voyages_rfp_2026-10-28/`

File	Content
`00_RFP_Analysis_and_Plan.md`	Internal RFP analysis, have/build table, CMS decision, first pricing, delivery plan
`01_Questions_for_Veena.md`	Cover email for the questions
`01b_Questions_source.md`	30 questions with defaults
`01c_Reply_to_clarifications_2026-10-31.md`	Reply to the client's seven clarification questions
`02_Panel_Debate.md`	16-voice debate; Common ground; Honest gaps by lens
`03_Functional_Breakdown.md`	Every RFP cell → build, acceptance, status, gap, hours
`04_Concept_Paper.md`	Concept « Du brief au retour »
`05_`, `06_`	Panel audits of the outgoing pages (11 lenses; project experts)
`07_Question_Coverage_Matrix.md`	MECE proof for the 30 questions
`08_–15_`	Audit rounds 1–3 and fix logs
`16_Proposal_Carryover.md`	Must-do items for the priced proposal
`17_Verification_Operator_Edits.md`	Verification of operator edits
`18_Payment_Terms_Vetting.md`	50/50 terms and guardrail table
`19_Final_QA_Reply_2026-10-31.md`	QA of the clarifications reply
`20_Internal_Founder_QA.md`	Founder Q&A: deliverability, price, architecture, risk
`99_INTERNAL_kickoff_call_checklist.md`	72-question long list
`HANDOFF.md`	What was built, verified facts, gates
`proposal/`	Proposal v1.0 (MD, DOCX, PDF), legal review, pre-contract clarifications PDF
`research/`	Effort estimate, market pricing, infra costs, functional suite, film renderer, model logs
`site/`	Concept site source (home, `pour-asset/`, `console/`, `questions/`, `_headers`)
`screens/`	Review screenshots
`advisory/`	This pack (MD, HTML, PDF)

Appendix D. Sources

Client. ASSET Voyages RFP, Version 0.4 EN, 28 October 2026 (restricted). Current site `asset-voyagesdaffaires.com`, fetched 28 October 2026, including `/solutions-voyages-affaires-pme/expertise-tarifaires/` and `/solutions-voyages-affaires-pme/politique-de-voyages/`.

Infrastructure (checked 28 October 2026, `D/research/infra_costs_2026.md`):

- Workers pricing: https://developers.cloudflare.com/workers/platform/pricing/
- Static assets billing: https://developers.cloudflare.com/workers/static-assets/billing-and-limitations/
- Pages limits: https://developers.cloudflare.com/pages/platform/limits/
- D1 pricing: https://developers.cloudflare.com/d1/platform/pricing/
- D1 Time Travel: https://developers.cloudflare.com/d1/reference/time-travel/
- D1 data location (EU jurisdiction): https://developers.cloudflare.com/d1/configuration/data-location/
- R2 pricing: https://developers.cloudflare.com/r2/pricing/
- Zero Trust account limits: https://developers.cloudflare.com/cloudflare-one/account-limits/
- Access one-time PIN and independent MFA: developers.cloudflare.com (Cloudflare One docs), checked 28 October 2026
- Turnstile plans: https://developers.cloudflare.com/turnstile/plans/
- Web Analytics: https://www.cloudflare.com/web-analytics/ (no custom events, per FAQ)
- Customer DPA: https://www.cloudflare.com/cloudflare-customer-dpa/
- Business SLA: https://www.cloudflare.com/business-sla/
- Incident reports: https://blog.cloudflare.com/cloudflare-service-outage-june-12-2025/ ; https://blog.cloudflare.com/fail-small-resilience-plan/ ; https://blog.cloudflare.com/5-december-2025-outage/
- Brevo: https://www.brevo.com/products/transactional-email/ · Resend: https://resend.com/pricing · UptimeRobot: https://uptimerobot.com/pricing/ · Postmark: https://postmarkapp.com/pricing · Amazon SES: https://aws.amazon.com/ses/pricing/

Market (`D/research/market_pricing_paris_2026.md`, 28 October 2026; mostly search summaries):

- Malt barometer: https://www.malt.fr/t/barometre-tarifs/tech/developpeur-backend/developpeur-fullstack
- TJMetre: https://tjmetre.fr/barometre · Freeland: https://barometre.freeland.com/tjm/developpeur
- La Fabrique du Net: https://www.lafabriquedunet.fr/agences/pages/agences-developpement-web/tarifs
- Agence2web: https://www.agence2web.com/tarifs-site-web/ · Seedweb: https://seedweb.fr/prix-site-internet/
- Ellebay: https://ellebay-digital.com/blog/cout-maintenance-site-web-2026 · Make Different: https://makedifferent.fr/blog/cout-maintenance-site-web/

Not sourced in this pack (flagged): CNIL prospect-retention period (cited from memory); Google Event structured-data policy (to check); Access free tier ≤ 50 users (third-party source); the original complexity and risk tables (reconstructed to match stated totals); French late-payment article numbering (to verify with an accountant).

Appendix E. Pre-review QA log

Pre-review QA on 31 Oct 2026, done by a reviewer playing a principal engineer. No scope decision was changed.

1. §3.3: functional suite figure changed from 62/62 to 65/65; the source is `research/functional.json`, dated 28 Oct. Appendix D no longer lists it as unsourced.
2. §5.8: removed the claim that email OTP is MFA. The default is now an IdP with enforced MFA, with an Open line for ASSET's IdP.
3. §5.10: "deploys as one unit" was wrong, since three Workers are three separate uploads. The text now describes the ordered deploy.
4. New §5.12 "Engineering specifics" covers load assumptions, D1 size and concurrency, Workers CPU for CSV import, the media pipeline, search and pagination, caching and freshness, draft preview, editor concurrency, i18n slugs, form rate limits, Access sessions, migration rollback, secret rotation with key IDs, GDPR data-subject requests and backups, audit-log hash chain, backup encryption and test data. Items we could not settle are marked "Open".
5. Checked the totals in §7.1: 219 rounds to ≈ 220, 238 + 48 = 286, and 20% contingency is correct.